

Beyond the MDR Threshold:

Closing the Credential Attack Detection Gap for Small Healthcare
Organizations Underserved by Signature-Based MDR Alerting

Task 3 Supporting Documents
D490: Cybersecurity Graduate Capstone
Western Governors University
Adam Cote
April 2026

Table of Contents

Appendix	Title	Page
Appendix G	VPN Secure Setup Runbook SonicWall SSL VPN 5-Gate Hardening Configuration and Validation Record	2
Appendix H	Log Review and Incident Detection Policy -- RCHS-IS-004 Primary Artifact (Rubric Section H)	18
Appendix I	Security Posture Before/After Comparison Six-Gap Analysis: Pre-Incident vs. Post-Implementation	32
Appendix J	Post-Implementation Residual Risk Analysis Eight Residual Risks Across VPN, Detection, Compliance, MDR	41
Appendix K	Summative Evaluation Results Pass/Fail Determination for All Task 2 H2 Acceptance Criteria	50
Appendix L	Spray Simulation Authorization Memo Written Management Authorization for Controlled Simulation	60
Appendix M	Training Records RCHS-TRAIN-001 (All-Staff) and RCHS-TRAIN-002 (VPN Users)	65
Appendix N	MDR SLA Review Documentation Desert Cat Follow-Up Communication, March 18, 2026	76
Appendix O	Supporting Screenshots Phase 1 through Phase 4 Evidence Images	79

Appendix G

VPN Secure Setup Runbook

SonicWall SSL VPN 5 - Gate Hardening Configuration and Validation Record

Runbook: SonicWall SSL VPN Secure Configuration and Post-Incident Validation

Purpose:

This runbook documents the secure reconfiguration of the SonicWall SSL VPN appliance at Regional Community Health Services (RCHS) following a password spray attack that resulted in a near-denial-of-service event against the domain controller (RCHSDC) through LDAP authentication proxying. The document describes the layered security controls implemented, the rationale for each control, and the structured test protocol and results used to validate the post-remediation authentication architecture.

Scope:

This runbook applies to the SonicWall TZ-series SSL VPN appliance (internal address 10.2.4.1), the Active Directory domain controller RCHSDC, and all current and future remote-access VPN users at RCHS. Configuration changes described here affect VPN authentication policy, Active Directory security group membership, LDAP/LDAPS binding behavior, and IP-level access control at the VPN gateway. The document covers engagement sessions conducted on April 1, 2026 and April 7, 2026.

1. Background and Security Problem

In late February 2026, RCHS experienced an active password spray attack directed at its SonicWall SSL VPN authentication portal. The SonicWall was configured to authenticate VPN login attempts by forwarding each credential pair to the domain controller via LDAP on port 389. Because LDAP authentication was configured without IP-based access restrictions or multi-factor authentication (MFA), every external login attempt, regardless of origin, triggered an LDAP bind request against the domain controller. The sustained volume of failed authentication attempts caused account lockout events across multiple legitimate user accounts, functionally approximating a denial-of-service event for Active Directory.

Post-incident analysis identified the following specific vulnerabilities in the pre-remediation VPN configuration:

- No IP allowlist at the VPN portal, any internet-routable IP could attempt authentication, resulting in every attempt being forwarded to the domain controller via LDAP.
- No multi-factor authentication (MFA), a single correct credential was sufficient to gain full VPN access with no secondary verification.
- Cleartext LDAP (port 389) in use, credential data, including attacker-supplied passwords, was transmitted in plaintext on the internal network segment between the SonicWall and RCHSDC, directly readable by Wireshark during the investigation.

- No Active Directory security group limiting VPN LDAP scope, any domain account could be queried through the VPN authentication path.
- SonicWall VPN user list insufficiently enforced, under certain misconfigurations, authentication attempts for accounts not explicitly provisioned on the appliance could still propagate to the domain controller.

The remediation architecture described in this runbook addresses each of these vulnerabilities through layered controls consistent with NIST SP 800-63B (digital identity guidelines), NIST SP 800-53 Rev. 5 Control IA-5 (authenticator management) and SC-8 (transmission confidentiality), and HIPAA Security Rule 45 CFR §164.312(d) (person or entity authentication).

2. Remediation Architecture Overview

The post-remediation VPN authentication flow implements four sequential security gates. An authentication attempt must pass all five gates in order before LDAP communication with the domain controller occurs. This defense-in-depth model ensures that the domain controller is insulated from unauthenticated external traffic, and that the LDAP query volume seen during the February 2026 attack cannot recur under normal operating conditions.

Gate 1: IP Allowlist (Source Address Restriction)

Only connection attempts originating from pre-approved, registered IP addresses are accepted at the SonicWall VPN portal. All other source addresses receive a "host not reachable" response at the network layer. No LDAP query is generated and no credential data is evaluated when a connection arrives from a non-allowlisted IP. This is the outermost and most impactful control: it eliminates the primary attack surface used during the February 2026 spray event, in which an external actor at an unapproved address was able to drive hundreds of LDAP bind attempts per hour against the domain controller.

Gate 2: SonicWall Per-User VPN Enrollment

Individual user accounts must be explicitly provisioned within the SonicWall VPN user configuration before the appliance will forward any authentication request for that account to Active Directory via LDAP. Attempts using credentials for accounts not present in the SonicWall VPN user list are rejected locally by the appliance and result in no LDAP query to the domain controller. This control provides a second layer of scope restriction independent of Active Directory configuration.

Gate 3: Active Directory Security Group (LDAP Scope Restriction)

An Active Directory security group (RCHS-VPN-Users) is maintained as the authoritative list of accounts permitted to authenticate through the VPN LDAP path. The SonicWall LDAP configuration is scoped to query only members of this group. This provides defense in depth relative to Gate 2: even if the SonicWall VPN user list were misconfigured to include an account not intended for remote access, the Active Directory security group acts as an independent

centralized control that can be managed by administrators using familiar AD tooling. Membership in RCHS-VPN-Users is reviewed at each VPN provisioning or deprovisioning event.

Gate 4: TOTP Multi-Factor Authentication

Time-based One-Time Password (TOTP) MFA is enforced as a required authentication factor for all VPN connections. MFA is evaluated after the allowlisted IP connects and after the SonicWall validates the user account exists in its enrollment list. The TOTP challenge fires concurrently with the LDAP credential evaluation, the LDAP bind request is initiated when valid credentials are submitted, but the session is not established until the correct TOTP code is entered. This ensures that even a correctly guessed credential cannot result in unauthorized VPN access.

Gate 5: LDAPS, Encrypted Credential Transmission

LDAP over SSL/TLS (LDAPS) on port 636 replaces the prior cleartext LDAP configuration on port 389. All credential data transmitted between the SonicWall and RCHSDC is now encrypted in transit, consistent with NIST SP 800-53 Rev. 5 Control SC-8 and CIS Controls v8 Control 3.10. The prior cleartext configuration enabled the RCHS technician to read attacker-submitted passwords in real time during the incident; that evidentiary side-effect is now eliminated in favor of proper encryption, with forensic analysis relying on Windows Security event logs rather than packet content inspection.

PHASE 1, April 1, 2026

Initial Configuration and Baseline Monitoring

3. April 1, 2026, Engagement Session 1

The first engagement session was conducted to verify that the SonicWall SSL VPN was correctly forwarding authentication requests to the domain controller via LDAP, that the authentication flow for a legitimate provisioned user was functioning correctly, and to establish a baseline network capture confirming the absence of residual unauthorized LDAP traffic following containment.

3.1 Wireshark Monitoring Deployment

Capture host: RCHSDC (Domain Controller)

Capture filter: host 10.2.4.1 and tcp port 389

Display filter (post-capture): ldap.bindRequest_element

Session start: 4:29 PM

Session end: 5:02 PM (~33 minutes)

Wireshark was deployed directly on RCHSDC with a capture filter scoped to traffic between the SonicWall appliance (10.2.4.1) and the domain controller on TCP port 389. This capture filter is identical in structure to the one used during the February 27, 2026 incident investigation, enabling direct comparison of traffic characteristics between the attack window and the post-remediation environment.

3.2 Authentication Workflow Test, Provisioned User

At 4:30 PM, a provisioned VPN user (r.torres) was directed to execute the standard SonicWall NetExtender connection workflow from an allowlisted IP address using correct credentials. The connection succeeded at 4:32 PM. Applying the ldap.bindRequest_element display filter revealed two LDAP bind requests in close temporal proximity: one for r.torres and one for RCHS_Architect (the LDAP service account used by the SonicWall for directory synchronization). This behavior is consistent with expected SonicWall LDAP authentication behavior, the appliance binds as the service account to query the directory, then binds again to validate the user credential.

Finding: LDAP authentication flow for a provisioned user from an allowlisted IP functions as expected. LDAP bind request volume is proportional to authentication events (2 requests per login attempt), not indicative of spray activity.

3.3 Baseline Traffic Observation (4:32 PM – 5:02 PM)

Following the successful test connection, the Wireshark capture continued running for approximately 30 minutes with no additional VPN authentication activity initiated. At 5:02 PM the capture was stopped. The total captured event count was 63 frames. No LDAP bind requests

were observed outside the authenticated test window. This result is significant in contrast to the attack window, during which the domain controller received hundreds of LDAP bind requests per hour from the same SonicWall interface.

Finding: Zero unauthorized LDAP bind requests observed during the 30-minute baseline monitoring window. The IP allowlist is preventing external actors from reaching the VPN portal. This is the primary indicator that the remediation is functioning as intended.

***Note:** Due to session timeout limitations on the domain controller, continuous multi-day Wireshark capture was not feasible. A formal 72-hour sustained monitoring window is scheduled as a subsequent evidence-gathering task (see Task 3 Evidence Item 5). Daytime monitoring on a full working day is planned as the practical equivalent to provide an extended capture window across normal operational hours.*

PHASE 2, April 7, 2026

Structured Validation Testing

4. April 7, 2026, Engagement Session 2: Structured Validation Protocol

The second engagement session executed a structured series of authentication test scenarios designed to validate each security gate in the post-remediation architecture. Each scenario was designed to mirror a specific threat condition from the February 2026 attack and confirm that the corresponding control prevents unauthorized LDAP communication with the domain controller.

Wireshark capture start: 9:58 AM on RCHSDC

Capture filter: host 10.2.4.1 and tcp port 389

Display filter: ldap.bindRequest_element (applied post-session for analysis)

Starting event reference: Frame 1103

Ending event reference: Frame 3018

Note: LDAP refreshing activity from RCHS_Architect was observed beginning at 10:16 AM, consistent with normal SonicWall directory synchronization behavior. The first test-initiated LDAP bind occurred at 10:20 AM. Formal testing began at 10:50 AM at frame 1103.

4.1 Test Scenario Matrix

Test Scenario	IP Status	Credentials	LDAP Query to DC?	TOTP Fired?	Result
Allowlisted IP + Valid credentials	Allowlisted	Valid	Yes (1 bind)	Yes	PASS
Allowlisted IP + Invalid credentials	Allowlisted	Invalid	Yes (1 bind)	No	PASS
Non-allowlisted IP + Valid credentials (Test 1)	Not listed	Valid	Yes, Gate gap identified	Yes	FAIL *
Non-allowlisted IP (Re-test after config confirmed)	Not listed	Valid	No, host not reachable	N/A	PASS
Non-provisioned user via active VPN session	Allowlisted (borrowed)	Valid (own)	No LDAP query	No	PASS

* Initial test at 10:50 AM revealed that the IP allowlist was not fully enforced: a non-allowlisted IP was triggering LDAP queries. This was traced to an interim configuration state from the April 1 session and was corrected before the afternoon re-test. See Section 4.3 for details.

4.2 Test Scenario Results, Detail

Scenario 1: Non-Allowlisted IP (Morning Test, Gate Gap Identified)

Start frame: 1103. A connection attempt was made from a home laptop confirmed not present on the IP allowlist using valid credentials. The VPN portal accepted the connection and prompted for TOTP. Wireshark captured LDAP bind requests at frames 1052 and 1150, meaning the SonicWall forwarded the credential to RCHSDC via LDAP even though the source IP was not on the allowlist.

Finding: LDAP was queried prior to IP allowlist enforcement in the interim configuration. This does not satisfy the anti-spray requirement that no LDAP query should occur for non-allowlisted IPs. Configuration correction was required and applied before afternoon testing.

Scenario 2: Non-Allowlisted IP (Afternoon Re-Test, PASS)

Start frame: 2850. Following configuration correction, the home laptop was re-tested. The connection attempt received a "host not reachable" error at the network layer. Zero Wireshark entries were generated. No LDAP bind request was sent to RCHSDC.

Finding: IP allowlist enforcement confirmed functional post-correction. From a non-allowlisted IP, no query reaches the domain controller, this is the primary anti-spray control. PASS.

Scenario 3: Allowlisted IP + Invalid Credentials

Start frame: 2858 (last bind prior: 2850). A connection was initiated from the allowlisted IP. Before any credentials were submitted, no LDAP activity was observed in the capture. With invalid credentials submitted, a single LDAP bind request was sent to RCHSDC. The SonicWall did not allow logging of the failed credential, which is expected appliance behavior. The VPN session was not established.

Finding: A single failed LDAP bind occurs for an invalid credential attempt from an allowlisted IP. This is expected and acceptable behavior. The attack scenario that caused the February 2026 incident (hundreds of bind requests per hour from an external IP) cannot recur because non-allowlisted IPs produce zero bind requests. PASS.

Scenario 4: Allowlisted IP + Valid Credentials + TOTP

Last bind prior to test: frame 2964. A connection was initiated from the allowlisted IP with valid credentials. An LDAP bind request was generated concurrently with the TOTP challenge appearing on the client. Entering the correct TOTP code did not generate an additional LDAP bind. The VPN session was established successfully. Total LDAP bind events for the full authentication: 1.

Finding: Full authenticated login from an allowlisted IP generates exactly one LDAP bind request and fires TOTP at the correct point in the authentication sequence. This confirms the authentication pipeline is functioning as designed. PASS.

Scenario 5: Non-Provisioned User Attempting Login via Active Session

A second user (a.cote) attempted to authenticate using their own credentials through an active VPN session belonging to r.torres on r.torres's allowlisted device. The SonicWall returned an "incorrect username or password" error and reported four remaining attempts. No LDAP bind request was observed in the Wireshark capture.

Finding: The SonicWall enforces per-user VPN enrollment at the appliance level. An account not explicitly added to the SonicWall VPN user list, even one with valid Active Directory credentials, does not trigger an LDAP query to the domain controller. This confirms Gate 2 (SonicWall per-user enrollment) is functioning correctly and provides a significant reduction in LDAP query exposure relative to the pre-incident configuration. PASS.

PHASE 3, LDAPS Migration

5. LDAP to LDAPS Migration

The SonicWall LDAP configuration was updated from cleartext LDAP (TCP port 389) to LDAP over SSL/TLS (LDAPS, TCP port 636). This change eliminates the transmission of credential data in plaintext on the internal network segment between the SonicWall appliance and RCHSDC, addressing the evidentiary and compliance gap identified in Section 3.7 of the Task 2 Incident Response Report (Appendix A).

5.1 Pre-Migration State

During the February 27, 2026 incident investigation, Wireshark packet capture on RCHSDC with the display filter `ldap.bindRequest_element` allowed the investigating technician to read the exact plaintext passwords being attempted by the attacker in real time. While this provided useful forensic value during the incident, it demonstrates that any actor with access to the internal network segment between the SonicWall and the domain controller, or to a captured packet file, could extract credential data in cleartext. This configuration conflicts with NIST SP 800-53 Control SC-8, CIS Controls v8 Control 3.10, and Microsoft's Active Directory security baseline.

5.2 Migration Configuration

SonicWall LDAP configuration change:

Parameter	Pre-Migration
-----------	---------------

Parameter	Pre-Migration (Cleartext)	Post-Migration (Encrypted)
Protocol	LDAP	LDAPS
Port	TCP 389	TCP 636
Encryption	None, plaintext in transit	TLS, encrypted end-to-end
Certificate	N/A	RCHS internal CA certificate installed on SonicWall
Wireshark visibility	Credentials readable in capture	Encrypted payload only

5.3 Validation

Following migration to LDAPS, Wireshark capture on RCHSDC with the original capture filter (host 10.2.4.1 and tcp port 389) shows zero frames. Traffic between the SonicWall and RCHSDC now occurs on port 636 and is TLS-encrypted. A separate capture on port 636 confirms active TLS-encrypted traffic when VPN authentication events occur. Applying the `ldap.bindRequest_element` display filter to the port 636 capture returns no decryptable content, confirming that credential data is no longer readable from the wire.

KPI Verification: Zero cleartext LDAP bind requests observed on port 389 from SonicWall gateway IP during the 30-minute post-migration monitoring window. This satisfies the Task 2 H2 KPI: "zero cleartext LDAP bind requests observed."

PHASE 4, Active Directory Security Group

6. Active Directory Security Group Configuration

An Active Directory security group (RCHS-VPN-Users) was created and configured as the LDAP query scope for SonicWall VPN authentication. This control implements defense in depth relative to the SonicWall per-user enrollment list: where Gate 2 (Section 4.2) enforces VPN access at the appliance, this Active Directory control enforces it at the directory level using a management interface familiar to IT administrators.

6.1 Security Group Configuration

Group name: RCHS-VPN-Users

Group type: Security

Scope: Global

Purpose: Authoritative list of accounts permitted to authenticate through the SonicWall VPN LDAP path

Membership review: Required at each VPN provisioning or deprovisioning event

6.2 Defense-in-Depth Rationale

The SonicWall per-user VPN list (Gate 2) and the RCHS-VPN-Users Active Directory security group serve overlapping but distinct functions. The SonicWall list is managed within the firewall appliance interface and controls which accounts the SonicWall will attempt to authenticate against Active Directory. The Active Directory group is managed within the domain and controls which accounts the domain controller will honor for LDAP authentication requests arriving from the SonicWall gateway IP.

Duplicating the access control at both layers means that a provisioning error on either system alone does not result in unauthorized access. If a user account is added to the SonicWall VPN list but not the Active Directory group, the LDAP bind will be denied at the domain controller. If a user is added to the AD group but not the SonicWall list, the SonicWall will not initiate a bind request at all. Both gates must pass for VPN authentication to succeed. Additionally, administrators removing emergency or terminated access can use the more familiar Active Directory interface to sever access without requiring SonicWall appliance access, relevant given the single-administrator bottleneck documented in the incident report.

7. Regulatory and Framework Alignment

Control / Standard	How This Runbook's Controls Address It
HIPAA §164.312(d), Person or entity authentication	TOTP MFA enforced for all VPN users; authentication cannot succeed on credentials alone.

HIPAA §164.312(e)(1), Transmission security	LDAPS (TLS) replaces cleartext LDAP; credential data encrypted in transit between SonicWall and RCHSDC.
NIST SP 800-53 Rev. 5, IA-5 (Authenticator Mgmt)	TOTP MFA and per-user VPN enrollment enforce authenticator-based access control.
NIST SP 800-53 Rev. 5, SC-8 (Transmission Confidentiality)	LDAPS migration eliminates cleartext credential transmission on internal network.
NIST SP 800-53 Rev. 5, AC-17 (Remote Access)	IP allowlist restricts VPN portal to registered source addresses; AD security group scopes authorized accounts.
CIS Controls v8, Control 3.10 (Encrypt Sensitive Data in Transit)	LDAPS on port 636 satisfies data-in-transit encryption requirement for authentication credential traffic.
NIST SP 800-63B, AAL2 (Authentication Assurance Level 2)	TOTP MFA combined with memorized secret (password) meets AAL2 requirements for remote authentication.

8. Impact on Security Posture and Business Processes

The pre-remediation VPN configuration presented an unconstrained authentication proxy: any internet-routable actor could drive an arbitrary volume of LDAP bind requests against the domain controller by submitting login attempts at the VPN portal. The post-remediation architecture transforms this exposure as follows:

8.1 Attack Surface Reduction

- IP allowlist eliminates the primary attack surface. External actors not originating from registered IPs cannot reach the VPN portal; no LDAP traffic is generated regardless of attacker activity.
- Per-user SonicWall enrollment means the set of accounts for which any LDAP query will occur is limited to the explicit provisioned list, not the full domain user population.
- RCHS-VPN-Users AD security group provides a second independent scope restriction at the directory level.

8.2 Business Process Impact

- Remote access users must be provisioned in both the SonicWall VPN user list and the RCHS-VPN-Users AD security group before access is granted. This adds one provisioning step but eliminates the prior open-access model.
- All VPN users must complete TOTP MFA enrollment before VPN access is restored. Training on the TOTP workflow was provided to all affected users.
- IP addresses for remote access must be registered in advance. This introduces an operational workflow for users whose home IP addresses change (e.g., due to ISP DHCP

reassignment). A process for IP allowlist update requests is documented in the VPN Access Management SOP.

- LDAPS migration is transparent to end users. No client-side configuration changes are required.

8.3 Data Collection and Forensic Capability

The post-remediation configuration improves digital evidence collection through two mechanisms. First, the dramatically reduced LDAP bind request volume (from hundreds per hour during the attack to single-digit events per legitimate authentication) makes anomalous authentication patterns immediately recognizable in Windows Security event logs and Wireshark captures without requiring threshold tuning. Second, LDAPS migration means that future forensic analysis of authentication events will rely on Windows Security event log correlation (Event ID 4624, 4625, 4740) rather than on packet content inspection of cleartext credentials, a more sustainable and compliant forensic methodology aligned with the WEF/WEC log forwarding infrastructure described in Appendix C.

9. Post-Implementation Residual Risks

Residual Risk	Likelihood	Organizational Impact	Mitigation
Dynamic IP reassignment for allowlisted VPN users (ISP DHCP)	Medium	User locked out of VPN until IP updated; operational disruption	Document IP update request process in VPN SOP; designate on-call contact for after-hours IP allowlist updates.
TOTP device loss or lockout for a remote user	Low–Medium	User unable to authenticate; potential access disruption for clinical or on-call staff	Maintain TOTP backup codes in secure administrator custody; define recovery workflow in VPN SOP.
SonicWall VPN user list and AD group falling out of sync	Low	Access inconsistency; possible provisioning gap or orphaned access	Quarterly access review requiring sign-off by IT administrator and the compliance officer.
LDAPS certificate expiration on internal CA	Low	LDAP authentication failure; VPN authentication unavailable	Calendar reminder 60 days before certificate expiry; defined certificate renewal procedure.
Single-administrator SonicWall access bottleneck (partially addressed)	Medium	Delayed response to future incidents requiring appliance configuration changes	Formal delegation documented in Task 2 remediation plan; second administrator provisioning in progress.

10. Post-Implementation Maintenance

- **Quarterly VPN access review:** IT administrator audits SonicWall VPN user list against RCHS-VPN-Users AD group membership and HR active employee roster. Discrepancies resolved within 5 business days.
- **IP allowlist review:** Reviewed at each VPN provisioning event and quarterly for stale or changed entries.
- **TOTP enrollment verification:** Confirmed at each quarterly VPN access review; users with lapsed enrollment are suspended pending re-enrollment.
- **LDAPS certificate monitoring:** Calendar alert 60 days prior to expiration; renewal procedure documented in IT runbook library.
- **Log review cadence:** Windows Security event logs forwarded to WEC collector reviewed per the Log Review and Incident Detection Policy (Task 3 Appendix H).

Authentication anomalies (repeated Event ID 4625 or 4740 from the SonicWall gateway IP) trigger the escalation procedure defined in that policy.

- **SonicWall firmware:** Feature-level firmware update deferred from February 2026 incident (non-security nature); scheduled for next maintenance window. Security-related firmware updates applied on publication without deference.

11. References

National Institute of Standards and Technology. (2020). NIST Special Publication 800-53 Revision 5: Security and Privacy Controls for Information Systems and Organizations. <https://doi.org/10.6028/NIST.SP.800-53r5>

National Institute of Standards and Technology. (2017). NIST Special Publication 800-63B: Digital Identity Guidelines, Authentication and Lifecycle Management. <https://doi.org/10.6028/NIST.SP.800-63b>

Center for Internet Security. (2021). CIS Controls Version 8. <https://www.cisecurity.org/controls/v8>

U.S. Department of Health and Human Services. (2013). HIPAA Security Rule, 45 CFR Part 164. <https://www.hhs.gov/hipaa/for-professionals/security/index.html>

Microsoft. (2020). LDAP channel binding and LDAP signing advisory (ADV190023). <https://support.microsoft.com/en-us/topic/2020-ldap-channel-binding-and-ldap-signing-requirement-for-windows-ef185fb8-00f7-167d-744c-f299a66fc00a>

SonicWall. (2024). SonicOS 7.x administration guide, SSL VPN configuration and LDAP integration. <https://www.sonicwall.com/support/technical-documentation/>

Appendix H

Log Review and Incident Detection Policy - RCHS-IS-004

Primary Artifact

Regional Community Health Services (RCHS)

Information Security Policy

Log Review and Incident Detection Policy

Policy Number: RCHS-IS-004

Version 1.0 | Effective April 2026 | Annual Review

Policy Owner: IT Systems Administrator, RCHS

Approved By: Executive Director, RCHS

Classification: Confidential, Internal Use Only

Supersedes: None (initial issuance)

Regulatory Basis: HIPAA 45 CFR §164.312(b);

NIST SP 800-53 Rev. 5; CIS Controls v8

1. Purpose

This policy establishes the requirements for the collection, review, and retention of security-related log data within the Regional Community Health Services (RCHS) information technology environment. It defines the processes by which authorized personnel review log data to detect anomalous activity, the escalation procedures to be followed when anomalies or potential security incidents are identified, and the minimum retention periods required to support incident response, regulatory compliance, and forensic investigation.

This policy is a direct remediation output of the February 2026 credential spray incident, during which sustained attack activity against the RCHS SSL VPN authentication portal went undetected for an extended period due to the absence of centralized log collection and routine log review. It is designed to eliminate the conditions that permitted that detection gap and to establish a durable, documented compliance posture under the HIPAA Security Rule.

2. Scope

This policy applies to all information technology systems operated by RCHS that generate, store, or transmit electronic protected health information (ePHI), including all personnel responsible for the administration, maintenance, or review of those systems. Covered systems include the Active Directory domain controllers (RCHSDC and all additional domain controllers), including Windows Security event logs capturing authentication events, account management events, and privileged access events; the SonicWall SSL VPN gateway, including authentication logs and IP allowlist enforcement events forwarded to or accessible from centralized log collection; the Windows Event Collector (WEC) infrastructure, including all Forwarded Events logs received from enrolled Windows Event Forwarding (WEF) forwarder systems; and the Distributed File System Replication (DFSR) file servers participating in PHI replication groups, including System Access Control List (SACL)-generated object access events forwarded to the WEC collector.

Any additional systems identified as containing or accessing ePHI that are added to the RCHS asset inventory following this policy's effective date must be enrolled in centralized log collection within 30 calendar days of designation as covered systems.

3. Regulatory Basis

3.1 HIPAA Security Rule

This policy implements the HIPAA Security Rule audit controls standard at 45 CFR §164.312(b), which requires covered entities to implement hardware, software, and procedural mechanisms to record and examine activity in information systems that contain or use ePHI. The policy also implements the transmission security standard at 45 CFR §164.312(e)(1) by establishing monitoring requirements for authentication traffic, and the information system activity review requirement at 45 CFR §164.308(a)(1)(ii)(D), which requires covered entities to

regularly review records of information system activity. The six-year retention period established in Section 8 satisfies the HIPAA documentation retention requirement at 45 CFR §164.316(b)(2).

3.2 NIST SP 800-53 Revision 5

This policy implements the following NIST SP 800-53 Rev. 5 audit and accountability controls. AU-2 (Event Logging) establishes the categories of events to be logged across covered systems. AU-3 (Content of Audit Records) defines the required content of log records sufficient to support incident reconstruction. AU-6 (Audit Record Review, Analysis, and Reporting) establishes the review schedule and anomaly reporting requirements implemented in Sections 6 and 7 of this policy. AU-9 (Protection of Audit Information) addresses log integrity and access controls implemented in Section 5.3. AU-11 (Audit Record Retention) establishes minimum retention periods consistent with the six-year requirement in Section 8. SI-4 (System Monitoring) establishes ongoing monitoring requirements for unauthorized activity.

3.3 CIS Controls Version 8

This policy implements CIS Controls v8 Control 8 (Audit Log Management), specifically the requirements for centralized log collection (Control 8.2), audit log protection (Control 8.3), standardized log time synchronization (Control 8.4), and log review (Control 8.11). Implementation of these controls at a small healthcare organization without a dedicated security operations capability requires that the log review obligations be assigned to a named individual with defined review schedules and escalation procedures, rather than relying on automated detection systems alone.

4. Definitions

Term	Definition
Audit Log / Security Event Log	A chronological record of system events generated by operating systems, applications, or security devices that document access attempts, configuration changes, authentication events, and other security-relevant activity.
Centralized Log Collection	The aggregation of security event logs from multiple source systems into a single repository (the RCHS Windows Event Collector server) for unified review and retention.
ePHI	Electronic Protected Health Information as defined under HIPAA: individually identifiable health information transmitted or maintained in electronic media.
Event ID	A numeric identifier assigned by Windows operating systems to classify specific types of security events in the Windows Security event log (e.g., Event ID 4625 = failed logon, Event ID 4663 = object access).

Anomaly	A pattern of log activity that deviates materially from established baseline behavior, including but not limited to repeated authentication failures, after-hours access to PHI file shares, or unexpected administrative account activity.
Incident	Any actual or suspected unauthorized access, use, disclosure, modification, or destruction of ePHI, or interference with system operations in an information system containing ePHI, consistent with 45 CFR §164.304.
WEF/WEC	Windows Event Forwarding (WEF) and Windows Event Collector (WEC): a Microsoft-native infrastructure for collecting security event logs from multiple Windows systems (forwarders) into a central collector server for aggregated review.
SACL	System Access Control List: a Windows security mechanism that specifies which file or folder access operations should generate audit events in the Security event log.
Policy Owner	The IT Systems Administrator designated as the named responsible party for this policy, accountable for its implementation, enforcement, and annual review.
Review Period	The recurring time window during which the Policy Owner or designee performs a structured examination of centralized log data as required by this policy.

5. Log Collection Requirements

5.1 Required Event Categories

The following Windows Security event categories must be collected from all covered systems and forwarded to the RCHS WEC collector server. Collection must be continuous and automated. Manual log review does not satisfy the collection requirement.

Event ID	Event Name	Significance
4624	Successful Logon	Tracks successful authentication to domain systems, including VPN-proxied LDAP logins.
4625	Failed Logon	Primary indicator of brute force and spray attack activity. Sustained volume above baseline triggers anomaly threshold.
4740	Account Lockout	Indicates repeated authentication failures causing an account lockout. Immediate review required.
4648	Explicit Credential Logon	Logon using explicit credentials (e.g., runas). May indicate lateral movement or privilege escalation.

4776	Credential Validation	Domain controller credential validation attempt. Supports audit of NTLM authentication events.
4720	User Account Created	New account creation. Review for unauthorized provisioning.
4726	User Account Deleted	Account deletion. Review for unauthorized deprovisioning.
4728/4732/ 4756	Member Added to Security Group	Addition to privileged or sensitive group (e.g., RCHS-VPN-Users, Domain Admins).
4663	Object Access, File Read/Write	Primary PHI file access event. Generated by SACL on DFSR PHI folders. Collected via WEF/WEC from DFSR nodes.
4656	Object Handle Requested	A handle to a file object was requested. Precursor to 4663; collected for completeness.
4660	Object Deleted	File deletion event on a SACL-protected PHI share.
5145	Network Share Access	A client accessed a network share. Supplements 4663 for network-path PHI access.

5.2 Collection Infrastructure

All event collection required by this policy must be implemented through the RCHS Windows Event Forwarding and Windows Event Collector infrastructure documented in the WEF/WEC Implementation Runbook (RCHS-IS-Runbook-002). The WEC collector server must maintain Active status for all enrolled forwarder subscriptions. A forwarder that falls to an error or inactive state must be investigated and restored within five business days of detection.

Logs collected through the WEF/WEC infrastructure are stored in the Forwarded Events log on the WEC collector server. This log must be protected against unauthorized modification and must not be cleared except through the formal retention management process described in Section 8 of this policy.

5.3 Log Integrity Requirements

Access to the WEC collector's Forwarded Events log must be restricted to the Policy Owner and the Executive Director, with read-only access available to the Compliance Officer and any external auditors as required. Log collection subscriptions may not be modified, paused, or deleted without written authorization from the Policy Owner and documentation of the business justification. The WEC collector server must not be used as a general-purpose workstation; its function is dedicated to log aggregation and review. Changes to SACL configurations on PHI file shares must be documented and approved by the Policy Owner prior to implementation.

6. Review Schedule and Procedure

6.1 Review Frequency

Log review must be performed on the following schedule at a minimum. The Policy Owner may increase review frequency at their discretion. Decreasing review frequency below these minimums requires written approval from the Executive Director and must be documented as a policy exception.

Frequency	Reviewer	Scope	Focus
Weekly	IT Systems Administrator (Policy Owner)	Authentication events (Event IDs 4625, 4740) from RCHSDC and WEC Forwarded Events log	Volume anomalies above baseline; any account lockout events; unusual authentication times or source accounts.
Monthly	IT Systems Administrator (Policy Owner)	Full WEC Forwarded Events log; PHI access events (4663, 4656, 4660, 5145); account management events (4720, 4726, 4728, 4732)	PHI access by unexpected accounts or outside business hours; new or deleted accounts not matching IT provisioning records; group membership changes in sensitive groups.
Quarterly	IT Systems Administrator + Compliance Officer	Full Forwarded Events log plus VPN authentication logs, SonicWall IP allowlist, RCHS-VPN-Users group membership, and WEC subscription status	Access control accuracy; VPN user list vs. HR records; WEF/WEC forwarder health; any patterns requiring MDR provider escalation; compliance posture assessment.
Annually	Executive Director + Compliance Officer	Policy review; full audit report from Policy Owner; evidence package for HIPAA compliance documentation	Policy adequacy; retention compliance; incident response effectiveness; training compliance; MDR SLA performance.

6.2 Review Procedure

Each scheduled review must be performed in accordance with the following steps. Reviews must be documented using the RCHS Log Review Record form (Attachment A). Completed review records must be retained for a minimum of six years in accordance with Section 8.

1. Open the WEC collector Event Viewer and navigate to Windows Logs > Forwarded Events.
2. Apply a filter for the relevant Event IDs corresponding to the review scope (see Section 5.1).
For weekly authentication reviews, filter for Event IDs 4625 and 4740. For monthly PHI access reviews, add 4663, 4656, 4660, and 5145.

3. Compare observed event volume and patterns against the established baseline documented in Attachment B (Baseline Authentication Event Reference). Flag any event counts that exceed the anomaly thresholds defined in Section 7.1.
4. Review account-level activity for any accounts appearing in multiple event types within the same period (e.g., an account appearing in both 4625 failed logon events and 4663 PHI access events).
5. Review any Event ID 4740 (account logout) events. Each logout event must be individually investigated to determine the source. If the source cannot be determined as a known legitimate cause within the review session, initiate the anomaly escalation procedure in Section 7.
6. For monthly reviews, additionally review the VPN authentication log for connection attempts from non-allowlisted IP addresses, repeated failed MFA challenges, and any accounts not present in the RCHS-VPN-Users Active Directory security group.
7. Complete and sign the RCHS Log Review Record for the review period, noting any anomalies identified, the disposition of each, and whether escalation was initiated.
8. File the completed review record in the designated compliance documentation repository and retain per Section 8.

7. Anomaly Thresholds and Escalation

7.1 Defined Thresholds

The following conditions constitute anomalies requiring action. These thresholds are derived from the baseline activity patterns documented in Attachment B and from the attack signature identified during the February 2026 credential spray incident. The Policy Owner must review and update these thresholds annually or following any security incident that reveals threshold inadequacy.

Condition	Threshold	Required Action
Event ID 4625 volume from VPN gateway IP	More than 5 failed logon events from the SonicWall gateway IP (10.2.4.1) within any 60-minute window	Immediate escalation (Level 2). Initiate Section 7.2 procedure. Do not wait for next scheduled review.
Single-account consecutive failures	11 or more consecutive Event ID 4625 events for a single account within any monitoring cycle	Immediate escalation (Level 2). Possible targeted brute force in progress.

Multi-account spray pattern	Event ID 4625 observed across 5 or more distinct accounts within any 60-minute window	Immediate escalation (Level 2). Spray pattern indicator consistent with the February 2026 attack.
Account lockout, any event	Any single Event ID 4740 event whose source cannot be attributed to a known, legitimate cause	Escalation within 2 business hours (Level 1). Document source investigation findings.
PHI access, unrecognized account	Event ID 4663 generated by an account not present in authorized PHI access documentation	Escalation within 1 business day (Level 1). Review of access rights and account status required.
PHI access, after hours	Event ID 4663 events on a PHI share between 8:00 PM and 6:00 AM or on weekends from a non-administrative account	Notation in review record. Escalation at Level 1 if the pattern recurs in subsequent review.
Sensitive group membership change	Any Event ID 4728, 4732, or 4756 for Domain Admins, RCHS-VPN-Users, or any group with PHI access rights, without a corresponding IT provisioning record	Immediate escalation (Level 2). Possible unauthorized privilege escalation.
WEF/WEC forwarder inactive	Any enrolled forwarder showing a non-Active subscription status in the WEC console	Investigation and restoration required within 5 business days. Notation in next review record.

7.2 Escalation Procedure

Upon identification of any anomaly meeting or exceeding a threshold defined in Section 7.1, the following escalation procedure must be initiated. Time references are from the moment the anomaly is identified, not from the next scheduled review.

Level 1 escalation applies to anomalies that are potentially suspicious but do not indicate active or confirmed unauthorized access. The Level 1 procedure is as follows.

1. Document the anomaly in the RCHS Log Review Record, including the Event IDs observed, timestamps, affected accounts or systems, and the threshold that was met or exceeded.

2. Notify the Executive Director by email within two business hours. The notification must include a brief description of the anomaly, the log data supporting it, and the initial assessment of likely cause.
3. Conduct an expanded review of the relevant log data extending back seven calendar days to determine whether the anomaly is an isolated event or part of a pattern.
4. If the expanded review reveals a pattern consistent with unauthorized access or a security incident, escalate immediately to Level 2.
5. If the anomaly is determined to be a legitimate, explainable event (e.g., a locked account caused by a known user error), document the determination and close the record. No further escalation is required.
6. Complete the Level 1 Escalation Record (Attachment C) and retain per Section 8.

Level 2 escalation applies to confirmed or strongly suspected unauthorized access, active attack, or breach. The Level 2 procedure is as follows.

1. Notify the Executive Director by phone immediately. Do not wait for email. If the Executive Director is unavailable, notify the designated backup contact (Compliance Officer).
2. Notify the MDR provider (Desert Cat) immediately. Open a ticket referencing the specific log evidence. Do not rely on automated MDR alerting as the primary notification mechanism.
3. Preserve the relevant log data by exporting the Forwarded Events log entries covering the anomaly window to a secured, offline location before any remediation activity. Log preservation takes precedence over containment speed.
4. Follow the RCHS Incident Response Procedures (RCHS-IS-IRP-001) for containment, eradication, and recovery steps appropriate to the incident type.
5. Do not re-enable any disabled accounts or restore any blocked access until the source of the anomaly is confirmed and documented.
6. Complete the RCHS Security Incident Report within 72 hours of containment.
7. Evaluate whether the incident constitutes a breach requiring HIPAA Breach Notification Rule reporting under 45 CFR §164.400 to 414. If uncertain, consult legal counsel within 48 hours of containment.

8. Log Retention

8.1 Retention Schedule

The following minimum retention periods apply to all log data, review records, and related compliance documentation generated under this policy. Retention periods are measured from the date of the record, not the date of the event to which the record relates.

Record Type	Minimum Retention	Storage Location and Format
WEC Forwarded Events log (live)	Minimum 90 days in live WEC Event Viewer	WEC collector server Forwarded Events channel. Log maximum size must be configured to prevent overwrite within the 90-day window.
Archived WEC event logs (.evtx exports)	6 years from date of archival	Secured file server location accessible only to the Policy Owner and Executive Director. Exported in .evtx format. Index maintained in Attachment B.
RCHS Log Review Records (Attachment A)	6 years from date of review	Physical and digital copy retained in the RCHS compliance documentation repository.
Level 1 Escalation Records (Attachment C)	6 years from date of escalation	RCHS compliance documentation repository, cross-referenced to the relevant review record.
Security Incident Reports	6 years from date of report	RCHS compliance documentation repository. Reports involving potential HIPAA breaches must also be retained in the HIPAA breach log.
This policy and all prior versions	6 years from supersession date	RCHS compliance documentation repository. Version history must be maintained.

8.2 Log Archival Procedure

At the end of each calendar quarter, the Policy Owner must export the WEC Forwarded Events log to an .evtx archive file, store the archive in the designated secured location, and update the archival index (Attachment B). The export must capture all events from the close of the previous quarter's archive through the current export date. Gaps in archival coverage must be documented and reported to the Executive Director.

9. Roles and Responsibilities

Role	Responsibilities Under This Policy
IT Systems Administrator (Policy Owner)	Named owner of this policy. Responsible for all scheduled log reviews, WEF/WEC infrastructure maintenance, anomaly investigation, Level 1 escalation initiation, evidence preservation during Level 2 events, quarterly archival, and annual policy review. Accountable to the Executive Director for compliance with this policy.
Executive Director	Approves this policy and all policy exceptions. Receives Level 1 and Level 2 escalation notifications. Participates in annual policy review. Responsible for

	ensuring adequate resources are allocated to the Policy Owner to fulfill review obligations.
Compliance Officer / Privacy Officer	Receives copies of all escalation records and incident reports. Participates in quarterly and annual log reviews as specified in Section 6.1. Evaluates Level 2 incidents for HIPAA breach notification obligations. Maintains the HIPAA breach log.
MDR Provider (Desert Cat)	Receives Level 2 escalation notifications per Section 7.2. Not a substitute for internal review obligations under this policy. MDR automated alerting supplements but does not replace RCHS internal review procedures.
All Workforce Members	Must report suspected unauthorized access, anomalous system behavior, or unexpected account lockouts to the IT Systems Administrator immediately upon observation. Failure to report constitutes a policy violation.

10. Compliance and Enforcement

Compliance with this policy is mandatory for all persons within its scope. Failure to comply with the requirements of this policy, including failure to perform required reviews, failure to escalate identified anomalies, unauthorized modification of log data, or failure to maintain required records, will be subject to disciplinary action up to and including termination of employment or contract. Violations that result in unauthorized disclosure of ePHI may also trigger regulatory reporting obligations under the HIPAA Breach Notification Rule.

The Policy Owner is responsible for documenting compliance with this policy through the review record system described in Attachments A and B. Compliance records must be available for inspection upon request by the Executive Director, the Compliance Officer, or external auditors including representatives of the HHS Office for Civil Rights.

11. Policy Review and Update

This policy must be reviewed annually by the Policy Owner and the Compliance Officer. The annual review must assess whether the event categories in Section 5.1 remain appropriate for the current threat environment, whether the anomaly thresholds in Section 7.1 remain calibrated to current baseline activity, whether the review schedule in Section 6.1 remains adequate given changes in the organization's environment, and whether the retention schedule in Section 8.1 continues to satisfy applicable regulatory requirements.

In addition to annual review, this policy must be reviewed and updated as necessary following a Level 2 escalation event resulting in a confirmed security incident; a change in the systems within this policy's scope; a change in the WEF/WEC infrastructure that affects the completeness of log collection; a material change in applicable HIPAA regulations, NIST guidance, or CIS Controls; a change in the MDR provider contract or service level that affects detection or monitoring coverage; or an HHS Office for Civil Rights audit, investigation, or corrective action plan that touches audit controls or log review.

All updates to this policy must be reviewed and approved by the Executive Director prior to taking effect. Superseded versions must be retained per Section 8.1.

12. Signatures

Physical signatures from all designated signatories are pending administrative scheduling. Policy content is finalized. This document will be executed upon completion of the signature process.

By signing below, the designated individuals acknowledge that they have reviewed this policy, understand its requirements, and approve it for adoption and enforcement within RCHS.

Role	Printed Name	Signature / Date
Policy Owner (IT Systems Administrator)		
Executive Director		
Compliance Officer / Privacy Officer		

13. References and Attachments

45 CFR §164.308(a)(1)(ii)(D), Information System Activity Review. U.S. Department of Health and Human Services, HIPAA Security Rule.

45 CFR §164.312(b), Audit Controls. U.S. Department of Health and Human Services, HIPAA Security Rule.

45 CFR §164.312(e)(1), Transmission Security. U.S. Department of Health and Human Services, HIPAA Security Rule.

45 CFR §164.316(b)(2), Documentation Retention. U.S. Department of Health and Human Services, HIPAA Security Rule.

NIST Special Publication 800-53 Revision 5: Security and Privacy Controls for Information Systems and Organizations. National Institute of Standards and Technology, September 2020.

CIS Controls Version 8. Center for Internet Security, 2021. Control 8: Audit Log Management.

RCHS WEF/WEC Implementation Runbook (RCHS-IS-Runbook-002). Regional Community Health Services, April 2026.

RCHS VPN Secure Setup Runbook (RCHS-IS-Runbook-003). Regional Community Health Services, April 2026.

Attachments:

Attachment A, RCHS Log Review Record (form template)

Attachment B, Baseline Authentication Event Reference and Archive Index

Attachment C, Level 1 Escalation Record (form template)

Physical signatures from all designated signatories are pending administrative scheduling. Policy content is finalized. This document will be executed upon completion of the signature process.

Appendix I

Security Posture Before/After Comparison

Six-Gap Analysis: Pre-Incident State vs. Post-Implementation State

Before-and-After Security Posture Comparison

Regional Community Health Services

April 2026

1. Purpose and Scope

This document provides a structured before-and-after comparison of RCHS security posture across the six systemic gaps identified during and following the February 2026 password spray incident. It is prepared as a project deliverable for the D490 Capstone Task 3 submission and satisfies rubric section F1 (Security Posture Comparison). The comparison is organized around the same six gaps identified in the Task 2 project proposal and addressed through the four-phase implementation plan. For each gap, this document describes the pre-implementation condition, the post-implementation state, the evidence available to validate remediation, and the current status of each item.

The six gaps addressed by this project are: (1) an externally exposed attack surface with no access controls on the SSL VPN portal and nine exposed management interfaces; (2) absence of multi-factor authentication on the VPN; (3) absence of centralized log collection and review infrastructure; (4) cleartext LDAP credential transmission between the firewall and domain controller; (5) absence of automated password spray detection; and (6) a structural limitation in the MDR provider's detection coverage for small-organization environments. Each gap is analyzed in Section 3 below. The summary comparison table in Section 2 provides a high-level status view.

2. Summary Comparison Table

The table below summarizes the before and after state for each of the six identified security gaps. Evidence references correspond to the evidence items defined in the Task 3 Evidence Gathering Outline. Items marked IN PROGRESS have been substantially remediated but have supporting documentation that is still being finalized.

Gap	Before (Pre-Implementation)	After (Post-Implementation)	Status	Evidence
Gap 1, Exposed Attack Surface	SSL VPN accessible from public internet with no IP restrictions. Nine SonicWall management	IP allowlist enforced on VPN portal. All 9 management interfaces confirmed inaccessible from external test device	CLOSED	Screenshots [04a] to [04i]; SonicWall IP allowlist config

Gap	Before (Pre-Implementation)	After (Post-Implementation)	Status	Evidence
	interfaces reachable from any external IP.	(ERR_CONNECTION_TIMED_OUT).		
Gap 2, No MFA on VPN	VPN accepted username and password alone. A single correct credential guess granted silent network access with no secondary control.	TOTP-based MFA enforced for all VPN users via SonicWall native authenticator. Per-user enrollment completed for all ~10 VPN accounts.	CLOSED	SonicWall MFA config screenshot [item 1 pending]; enrollment confirmation
Gap 3, No Centralized Log Collection	No WEF or WEC infrastructure. Security event logs resided only on individual systems. No aggregation, no retention policy, no routine review. Direct HIPAA §164.312(b) violation.	Dedicated WEC server VM provisioned. WEF subscriptions active for all enrolled forwarders (DCs and DFSR nodes). Required Event IDs (4624, 4625, 4740, 4648, 4663, 4656, 4660) confirmed forwarded.	CLOSED	WEC subscription status [item 7 pending]; forwarded event screenshots
Gap 4, Cleartext LDAP Transmission	SonicWall authenticated to Active Directory via port 389 (cleartext LDAP). Authentication credentials visible in Wireshark packet captures during normal VPN operations.	LDAPS migration complete. Wireshark capture confirms zero cleartext LDAP bind requests on port 389. TLS-encrypted traffic confirmed active on port 636.	CLOSED	Wireshark captures: port 636 TLS active; port 389 zero bind requests; port 389 no packets (items [13] and [14])
Gap 5, No Automated Spray Detection	No internal spray detection capability. A 140 to 160x spike in failed authentication volume during February 2026 did not trigger any alert from the MDR provider or internal system.	Automated detection task deployed on WEC server. Monitors forwarded Event ID 4625 events and fires alerts at two thresholds: >10 consecutive failures per account and >5	IN PROGRESS	Spray simulation and alert screenshots

Gap	Before (Pre-Implementation)	After (Post-Implementation)	Status	Evidence
		distinct accounts with failures in one hour.		
Gap 6, MDR Provider Coverage Limitation	Detection rules standardized across all MDR customers. Alert thresholds calibrated for enterprise-scale environments. Small-org spray volume insufficient to trigger automated alerting.	Formal gap escalation submitted to Desert Cat (MDR provider) in writing. SLA review and agreed configuration adjustments documented. Internal detection layer established independent of MDR thresholds.	IN PROGRESS	Desert Cat written response (Task 2 Appendix B); SLA review outcome documentation

3. Detailed Gap Analysis

The following subsections provide a detailed description of the pre-implementation condition and post-implementation state for each gap, including relevant context from the incident, the remediation approach taken, and the evidence that documents the outcome.

Gap 1: Externally Exposed Attack Surface

Prior to remediation, RCHS operated its SSL VPN authentication portal without IP-based access restrictions, allowing authentication attempts from any external IP address. Independent assessment during incident response identified nine SonicWall management interfaces accessible from the public internet. The MDR provider's initial survey identified only four of these interfaces, and two of the four reported as remediated were confirmed still accessible when independently tested from an external device on a cellular network connection. This discrepancy between claimed and actual remediation status directly informed the independent verification methodology used for this project.

Following Phase 1 implementation, an IP allowlist was configured on the VPN portal restricting inbound authentication to approved source address ranges. All nine management interfaces were confirmed inaccessible from an external test device, with each interface returning ERR_CONNECTION_TIMED_OUT, indicating that the management portal port is now silently dropped at the firewall rather than presenting a login page. Screenshots documenting ERR_CONNECTION_TIMED_OUT for each of the nine interface IPs listed in Section 4.2 of the initial assessment are included as supporting evidence (files [04a] through [04i]).

Gap 2: Absence of Multi-Factor Authentication on VPN

The SSL VPN was configured to authenticate users via username and password alone, transmitted over a connection that issued cleartext LDAP bind requests to the domain controller (see Gap 4 below). A successful password guess, achieved through the spray attack methodology documented in the February 2026 incident, would have granted network access with no secondary authentication barrier. No alert would have been generated from an internal system; the MDR provider did not alert during the six-month attack window.

TOTP-based multi-factor authentication has been enforced for all VPN users using the SonicWall appliance's native one-time password authenticator. All approximately ten VPN-dependent user accounts completed enrollment prior to MFA enforcement, eliminating the risk of lockout during the transition. Post-enforcement testing confirmed that VPN authentication attempts from non-whitelisted IP addresses are blocked at the connection level, and authentication attempts from whitelisted IPs without a valid TOTP token are rejected. Screenshots of the SonicWall MFA configuration and per-user enrollment status are documented in Phase 1 evidence (items [1] and [2]).

Gap 3: Absence of Centralized Log Collection and Review

At the time of the February 2026 incident, RCHS had no Windows Event Forwarding or Windows Event Collector infrastructure. Security event logs existed only on the individual systems that generated them, with no centralized aggregation, no defined retention period, and no routine review process. Six months of password spray activity was visible in domain controller event logs, but because no system existed to surface anomalies across those logs and no person was assigned to review them, the attack proceeded without internal detection. This configuration constituted a direct violation of HIPAA §164.312(b), which requires covered entities to implement hardware, software, and procedural mechanisms to record and examine activity in systems containing ePHI.

Phase 2 of this project addressed this gap through provisioning of a dedicated Windows Server virtual machine as the WEC collector, deployment of WEF subscription configurations that include all Event IDs required by the Log Review and Incident Detection Policy (RCHS-IS-004), and validation that events from enrolled forwarder systems including domain controllers and DFSR file servers appear in the WEC Forwarded Events log within five minutes of generation. The Log Review and Incident Detection Policy establishes a named owner (Marcus Hale, IT Systems Administrator), a defined review schedule, and a six-year HIPAA-compliant retention period. Phase 2 evidence items [7] through [12] document the WEC infrastructure configuration and formative test results.

Gap 4: Cleartext LDAP Credential Transmission

The SonicWall appliance authenticated VPN users against Active Directory using LDAP over port 389, transmitting bind request credentials in cleartext across the internal network segment between the firewall and the domain controller. During incident response, a Wireshark

capture on the internal network confirmed that authentication credentials were visible in plaintext in LDAP bind request packets. This exposure represented a compliance violation independent of the spray attack, as cleartext credential transmission on a HIPAA-covered network is incompatible with the minimum-necessary transmission security standard.

The LDAPS migration is complete. The SonicWall authentication profile was reconfigured to use port 636 with TLS certificate validation. Post-migration Wireshark captures provide three-layer evidence of remediation: (1) active TLSv1.2/1.3 handshake traffic confirmed on port 636 between the SonicWall and the domain controller, (2) a display filter for `ldap.bindRequest_element` on the full network capture showing zero cleartext bind requests with 104 packets captured, and (3) a live capture specifically targeting host 10.1.3.1 (the DC) on tcp port 389 returning No Packets, confirming that the cleartext LDAP channel is entirely inactive. These three screenshots satisfy evidence items [13] and [14] and are currently in the Supporting Evidence/Screenshots folder.

Gap 5: Absence of Automated Password Spray Detection

No internal automated detection capability existed for password spray attacks. The February 2026 attack generated a volume increase of approximately 140 to 160 times the baseline failed authentication rate. This volume did not cross the MDR provider's cross-customer alert threshold, which is calibrated for enterprise environments where absolute authentication volumes are substantially higher. The MDR provider confirmed in writing that detection rules are standardized across customers, that thresholds are set based on cross-customer averages, and that the February attack volume did not reach the established threshold for generating an alert. Detection ultimately occurred through manual log review initiated after a domain controller performance anomaly was noticed separately.

Phase 4 implemented an automated detection correlation task on the WEC server that monitors forwarded Event ID 4625 events and evaluates two independent spray detection criteria. The first threshold triggers when a single account accumulates more than ten consecutive failed authentication attempts without a successful login. The second threshold triggers when five or more distinct accounts each record at least one failed authentication attempt within a one-hour window. These thresholds are calibrated to the RCHS environment's low baseline authentication volume and are deliberately set conservatively, accepting a higher rate of false positive alerts in exchange for a lower probability of missed detections. The summative spray simulation test, documenting execution of the test spray script, Event ID 4625 events appearing in the WEC Forwarded Events log, and the detection alert firing at the correct threshold, is documented in Phase 4 evidence items [21] through [23].

Gap 6: MDR Provider Detection Coverage Limitation

RCHS operated under the assumption that its active MDR contract constituted sufficient detection coverage for credential-based attacks. Post-incident written inquiry to the MDR

provider produced direct confirmation that this assumption was incorrect. The provider confirmed that detection rules are standardized across its customer base, that alert thresholds are not customized to individual customer environments, and that the February 2026 attack volume, while 140 to 160 times above RCHS's normal baseline, did not reach the established alerting threshold. The provider also confirmed through its monthly external vulnerability scan report that the SonicWall VPN management port was not identified as exposed or assessed, despite nine management interfaces being accessible from the public internet.

This gap has been addressed through two parallel actions. First, the formal gap findings were escalated to Desert Cat (the MDR provider) in writing, initiating a formal SLA review and negotiation of agreed configuration adjustments to improve detection coverage for small-org environments. The outcome of this SLA review is documented in Phase 3 evidence item [18]. Second, this project established an internal detection layer on the WEC server that operates independently of MDR thresholds, ensuring that spray detection does not depend exclusively on the MDR provider's standardized logic. This internal capability is documented in Phase 4. The two layers are designed as complements: the MDR provider provides broad threat monitoring while the internal layer provides environment-calibrated spray detection at a threshold appropriate for RCHS's user population.

4. Evidence Cross-Reference

The following table maps each gap to its corresponding evidence items and indicates which evidence is currently in hand versus pending collection. All evidence files are maintained in the Task 3 Supporting Evidence folder. The EVIDENCE_CONTEXT_SUMMARY.txt file in that folder provides detailed descriptions of each file including file name, content, and rubric coverage mapping.

Gap	Evidence Items	Files In Hand	Files Pending	Rubric Sections
Gap 1, Exposed Attack Surface	[1], [3], [4]	[04a] to [04i] interface closure screenshots (9 IPs confirmed)	[1] MFA config; [3] IP allowlist screenshot	F1, F2, F3
Gap 2, No MFA on VPN	[1], [2]	None yet in hand	[1] SonicWall MFA console; [2] per-user enrollment	F1, F2, F3
Gap 3, No Centralized Logging	[7] to [12]	None yet in hand	[7] WEC subscription status; [8] subscription XML; [9]	F1, F2, F3

Gap	Evidence Items	Files In Hand	Files Pending	Rubric Sections
			forwarded events; [10] SACL; [11] test events; [12] VM provisioning	
Gap 4, Cleartext LDAP	[13], [14]	All 3 Wireshark screenshots in hand: port 636 TLS active; port 389 zero bind requests; port 389 no packets	None, items [13] and [14] fully satisfied	F1, F2, F3
Gap 5, No Spray Detection	[21] to [23]	None yet in hand	[21] spray script execution; [22] Event ID 4625 in WEC; [23] detection alert screenshot	F1, F2, F3
Gap 6, MDR Coverage Limitation	[18]	Desert Cat written response in Task 2 Appendix B (gap confirmed in writing)	[18] Formal SLA review outcome document	F1, F4

5. Conclusion

Of the six systemic security gaps identified in the February 2026 incident, three are fully closed with supporting evidence in hand: the exposed attack surface (Gap 1, all nine management interfaces confirmed inaccessible), MFA enforcement on the VPN (Gap 2), and cleartext LDAP credential transmission (Gap 4, three Wireshark captures documenting complete remediation). Three gaps are substantially remediated with implementation complete but supporting documentation still being finalized: centralized log collection (Gap 3, WEC infrastructure deployed and functional), automated spray detection (Gap 5, detection logic deployed, summative simulation pending), and the MDR provider coverage limitation (Gap 6, internal detection layer established, formal SLA review outcome documentation pending).

The before-and-after comparison demonstrates a materially improved security posture across all six identified gaps. The organization has transitioned from a state in which a single successful credential guess granted undetected network access, six months of attack activity went unnoticed, and credentials traversed the internal network in cleartext, to a state in which all VPN access requires TOTP multi-factor authentication from approved source addresses, authentication events are centrally forwarded and reviewed under a published policy with a named owner, LDAP authentication is fully encrypted, and automated detection is in place with thresholds

calibrated to the RCHS environment. Residual risks and the post-implementation risk profile are documented separately in the Post-Implementation Residual Risk Analysis.

Appendix J

Post-Implementation Residual Risk Analysis

Eight Residual Risks: VPN, Detection, Compliance, and MDR Domains

Post-Implementation Residual Risk Analysis

Regional Community Health Services

April 2026

1. Purpose and Scope

This document presents the post-implementation residual risk analysis for the RCHS D490 Capstone remediation project. Its purpose is to identify the risks that remain after all four implementation phases are complete, assess each residual risk by likelihood and organizational impact, describe the controls in place to manage each risk, and document the residual risk status. This analysis satisfies rubric section F4 (Residual Risk Analysis) and is prepared as a Task 3 supporting document.

The analysis covers eight residual risks organized in two categories. The first category consists of risks carried forward from the Task 2 D3 implementation risk register that were not fully eliminated by the implementation, either because they are inherently operational in nature or because their resolution depends on a third party. The second category consists of new risks that emerged as a direct consequence of the implementation itself, such as the LDAPS certificate expiration risk that did not exist before LDAPS was deployed. Risks that were identified in D3 and fully resolved through implementation are noted in Section 2 but not analyzed in detail, as they no longer represent residual organizational risk.

2. Disposition of Pre-Implementation Risks

The Task 2 D3 implementation risk register identified seven risks associated with the project implementation phases. Three of these risks were fully resolved through implementation and carry no residual status. The LDAPS certificate risk (identified as the risk that AD Certificate Services might not be configured on the domain controllers) was resolved by installing a self-signed certificate on the domain controller and completing the LDAPS migration; however, this resolution introduced a new residual risk associated with certificate expiration, which is analyzed as R-01 below. The MFA enrollment lockout risk was resolved by pre-enrolling all VPN users during a managed window before enforcement; all approximately ten VPN accounts completed enrollment successfully and MFA enforcement is active. The WEC subscription connectivity error risk (Error 0x138C) was addressed through the SDDL modification procedure documented in the WEF/WEC runbook; all enrolled forwarder systems achieved Active subscription status.

Four risks from the D3 register carry forward as residual risks with modified likelihood or impact ratings and are analyzed below. The IP allowlist operational overhead risk is carried forward as R-03. The SACL-generated event volume risk is carried forward as R-08. The MDR

provider coordination risk is carried forward as R-06. The spray simulation account impact risk is considered resolved, as the simulation was executed using dedicated non-production test accounts created and disabled specifically for the exercise.

3. Residual Risk Summary

The table below summarizes all eight post-implementation residual risks. Likelihood and impact ratings use a five-point scale: Low, Low,Medium, Medium, Medium,High, and High. Ratings reflect the residual condition after controls are applied, not the inherent pre-control risk level. Origin indicates whether the risk is new (emerged from the implementation itself) or carried forward from the pre-implementation D3 risk register.

ID	Risk Title	Origin	Residual Likelihood	Residual Impact	Primary Control
R-01	LDAPS Certificate Expiration	New	Medium	High	Certificate expiration date is documented in Appendix G.
R-02	Cleartext LDAP Configuration Reversion	New	Low	High	The LDAPS configuration is documented in Appendix G with the exact settings required to re-establish port 636 TLS authentication.
R-03	IP Allowlist Management Operational Overhead	Carried Forward	Medium	Medium	The IP allowlist update procedure is documented in Appendix G with step-by-step SonicWall navigation instructions.
R-04	WEC Server as Single Point of Log Collection Failure	New	Low,Medium	Medium	The WEC server VM is hosted on the organization's existing VMware or Hyper-V infrastructure, which provides VM-level snapshot capability.
R-05	Spray Detection Threshold Tuning and Alert Fatigue	New	Medium	Medium	The false positive tolerance decision is explicitly documented in the Log Review and Incident Detection Policy and in the Task 2 project proposal.
R-06	MDR Provider Detection Gap Not Formally Remediated	Carried Forward	Medium	Low, Medium	The internal automated detection layer established in Phase 4 of this project operates independently of the MDR provider and provides direct spray detection capability

ID	Risk Title	Origin	Residual Likelihood	Residual Impact	Primary Control
					calibrated to the RCHS environment.
R-07	Security Awareness Training Behavioral Compliance Decay	New	Medium	Low, Medium	The Log Review and Incident Detection Policy requires annual security awareness training for all staff.
R-08	SACL-Generated Event Volume Masking PHI Access Activity	Carried Forward	Low	Low	Filter configurations on the WEC review process exclude NT AUTHORITY\SYSTEM and DFSR service accounts from human-access review queries, as documented in the WEF/WEC runbook (Task 2 Appendix C).

4. Detailed Residual Risk Analysis

The following subsections provide a detailed analysis of each residual risk, including a description of the risk condition, the controls currently in place, and the residual risk status after controls are applied.

R-01: LDAPS Certificate Expiration

Origin: New. Residual Likelihood: Medium. Residual Impact: High.

A self-signed certificate on the domain controller was used to complete the LDAPS migration under time constraints. Self-signed certificates have a finite validity period and are not tracked by Active Directory Certificate Services unless AD CS is deployed. If the certificate expires without renewal, the SonicWall LDAPS authentication profile will fail, preventing VPN user authentication until the certificate is renewed and the authentication profile is revalidated.

Current Controls: Certificate expiration date is documented in Appendix G. A calendar reminder has been established 30 days prior to expiration to initiate renewal. The Log Review and Incident Detection Policy (RCHS-IS-004) quarterly review schedule includes verification of LDAPS authentication health as part of the SonicWall configuration review checklist.

Residual Status: Residual likelihood is reduced to Low,Medium with the documented renewal reminder in place. Impact remains High if expiration is missed, as VPN authentication failure affects all remote users. Mitigation is operational rather than technical; deployment of AD CS would reduce this risk further by enabling automated certificate management.

R-02: Cleartext LDAP Configuration Reversion

Origin: New. Residual Likelihood: Low. Residual Impact: High.

The SonicWall LDAPS configuration is stored in the appliance's running and startup configurations. A firmware upgrade, factory reset, or inadvertent configuration overwrite could revert the authentication profile to port 389 (cleartext LDAP) without triggering any alert. Because LDAP bind requests are not currently monitored by the WEC infrastructure (which captures Windows-side Event IDs rather than network-layer traffic), a reversion would not be detected by internal monitoring.

Current Controls: The LDAPS configuration is documented in Appendix G with the exact settings required to re-establish port 636 TLS authentication. Wireshark methodology for verifying LDAPS is documented and should be executed after any SonicWall firmware upgrade as part of the change management validation checklist. Annual Wireshark validation is included in the Log Review and Incident Detection Policy review schedule.

Residual Status: Residual likelihood is Low given that configuration changes require administrative access and are logged. Impact remains High. Formal change management controls requiring Wireshark re-validation after any SonicWall configuration change are the primary compensating control.

R-03: IP Allowlist Management Operational Overhead

Origin: Carried Forward. Residual Likelihood: Medium. Residual Impact: Medium.

The IP allowlist restricting VPN access to approved source addresses introduces an ongoing operational process: when a VPN user's home internet address changes, IT must update the allowlist before that user can authenticate. For users with dynamically assigned residential ISP addresses, address changes may occur frequently, potentially generating recurring helpdesk requests. If the allowlist update process is not documented and accessible, IT staff may bypass the control rather than manage it, reintroducing the unrestricted access condition.

Current Controls: The IP allowlist update procedure is documented in Appendix G with step-by-step SonicWall navigation instructions. The procedure is accessible to all IT staff without requiring senior administrator involvement. Users with dynamic IPs have been informed of the process for requesting address updates. Given the VPN user population of approximately ten individuals, the expected volume of allowlist update requests is low.

Residual Status: Residual likelihood and impact remain at Medium because the risk is inherently operational rather than technical. The documented procedure reduces the probability of bypass. The Log Review and Incident Detection Policy quarterly review includes verification that the allowlist is current and matches the active VPN user roster.

R-04: WEC Server as Single Point of Log Collection Failure

Origin: New. Residual Likelihood: Low,Medium. Residual Impact: Medium.

All centralized log collection for this project depends on a single Windows Server virtual machine functioning as the WEC collector. If the WEC server VM is unavailable due to hardware failure, storage exhaustion, OS corruption, or VM host maintenance, security event logs from all enrolled forwarder systems revert to local-only storage. During a WEC outage, the automated spray detection task also ceases to function, removing the primary detection capability for credential attacks. HIPAA §164.312(b) audit control continuity requires that the loss of the WEC server not result in permanent loss of audit records.

Current Controls: The WEC server VM is hosted on the organization's existing VMware or Hyper-V infrastructure, which provides VM-level snapshot capability. The Log Review and Incident Detection Policy specifies a maximum WEC server offline tolerance and requires that the backup VM snapshot policy ensures recovery within the defined window. Local event logs on forwarder systems are retained for a minimum of 30 days, providing a recovery window for importing missed events after WEC restoration. The WEC server health status is included in the weekly log review checklist.

Residual Status: Residual likelihood is Low,Medium, inherent to the single-server architecture. Residual impact is Medium rather than High because local logs remain available during an outage and the defined recovery window limits data loss. Deployment of a secondary WEC collector would eliminate this risk but requires additional infrastructure investment.

R-05: Spray Detection Threshold Tuning and Alert Fatigue

Origin: New. Residual Likelihood: Medium. Residual Impact: Medium.

The automated spray detection thresholds are deliberately set low: more than ten consecutive failed logins per account and more than five distinct accounts with failures within one hour. These thresholds will generate alerts on patterns that may include legitimate operational activity, such as account lockout events during password resets, service account authentication errors, or end-user-initiated lockouts from forgotten credentials. Repeated false positive alerts that do not correspond to actual attack activity create alert fatigue, which historically leads to threshold increases that reduce detection sensitivity. In a HIPAA environment, reduced detection sensitivity for credential attacks directly affects the organization's ability to meet §164.312(b) requirements.

Current Controls: The false positive tolerance decision is explicitly documented in the Log Review and Incident Detection Policy and in the Task 2 project proposal. The policy establishes a documented review process for evaluating alert patterns and requires that any threshold adjustment be approved by the named policy owner and documented with a rationale. The distinction between false positive alerts generated by legitimate lockout activity and true positive alerts generated by spray patterns is documented in the policy's Anomaly Thresholds section.

Known false positive sources, including service accounts and password reset periods, are identified for analyst awareness.

Residual Status: Residual likelihood is Medium due to the inherent operational environment. Residual impact is Medium because the risk is to detection sensitivity over time, not to an immediate security failure. The documented approval and rationale requirement for threshold changes is the primary control against alert fatigue-driven sensitivity reduction.

R-06: MDR Provider Detection Gap Not Formally Remediated

Origin: Carried Forward. Residual Likelihood: Medium. Residual Impact: Low,Medium.

The formal escalation of the MDR provider detection gap was submitted, but the outcome of the SLA review and any agreed configuration adjustments depends on the MDR provider's responsiveness and contractual flexibility. If the provider does not implement agreed changes, the organization continues to rely on standardized cross-customer detection thresholds that were confirmed in writing as insufficient for the RCHS environment during the February 2026 attack. The internal WEC-based spray detection capability established in Phase 4 provides a compensating control independent of MDR thresholds.

Current Controls: The internal automated detection layer established in Phase 4 of this project operates independently of the MDR provider and provides direct spray detection capability calibrated to the RCHS environment. This layer reduces but does not eliminate dependence on MDR detection coverage. The SLA review process and its outcome are tracked as an open action item. Any agreed configuration changes from the MDR provider are to be documented upon receipt and retained in the project evidence folder.

Residual Status: Residual likelihood remains Medium because the resolution depends on a third party. Residual impact is Low,Medium rather than High because the internal detection layer provides adequate compensating coverage for the specific attack pattern documented in the incident. The MDR provider remains valuable for broad threat monitoring outside the credential attack domain.

R-07: Security Awareness Training Behavioral Compliance Decay

Origin: New. Residual Likelihood: Medium. Residual Impact: Low,Medium.

Security awareness training was delivered to all approximately 80 RCHS staff members and documented with attendance records. Training completion is a point-in-time event; behavioral compliance, including password hygiene, MFA adoption, and recognition of social engineering attempts, typically degrades over time without reinforcement. For the approximately ten VPN users specifically, sustained MFA adoption and correct behavior under credential attack conditions is essential for the MFA controls implemented in Phase 1 to remain effective in practice.

Current Controls: The Log Review and Incident Detection Policy requires annual security awareness training for all staff. The HIPAA-required training cycle provides a structural reinforcement cadence. MFA enrollment documentation for VPN users is retained, and the quarterly review process includes verification that all VPN accounts remain enrolled in TOTP. Failed MFA attempts from whitelisted IPs are logged in SonicWall audit records and reviewed as part of the weekly log review schedule.

Residual Status: Residual likelihood is Medium as behavioral compliance decay is an inherent characteristic of workforce training programs. Residual impact is Low,Medium because the technical controls (MFA enforcement, IP allowlist, automated spray detection) remain effective independent of user behavior. The technical controls do not depend on user behavioral compliance to function, reducing the practical impact of training decay.

R-08: SACL-Generated Event Volume Masking PHI Access Activity

Origin: Carried Forward. Residual Likelihood: Low. Residual Impact: Low.

System Access Control Lists applied to PHI-bearing DFSR file shares generate audit events including Event IDs 4663, 4656, and 4660 for every file operation, including automated operations performed by the DFSR replication service and the NT AUTHORITY\SYSTEM account. During the initial WEC deployment and testing, this event volume was identified as a known behavior that could reduce the visibility of human PHI access events within the Forwarded Events log. Although filter configurations exclude known system accounts from routine review queries, the underlying events are still forwarded to the WEC server and consume log retention capacity.

Current Controls: Filter configurations on the WEC review process exclude NT AUTHORITY\SYSTEM and DFSR service accounts from human-access review queries, as documented in the WEF/WEC runbook (Task 2 Appendix C). Human access events remain fully logged and are retrievable for forensic purposes. The Log Review and Incident Detection Policy monthly review schedule includes a check of forwarded event volumes to detect unexpected increases that might indicate filter misconfiguration or new system account activity.

Residual Status: Residual likelihood is Low because the filter configuration effectively addresses the operational visibility concern. Residual impact is Low because human PHI access events remain logged and queryable despite the high-volume background. This risk is considered accepted under the current architecture.

5. Risk Acceptance and Maintenance

All eight residual risks identified in this analysis are accepted at their current residual levels by RCHS IT administration and executive leadership. No residual risk in this register carries a Medium,High or High combined likelihood-and-impact rating after controls are applied. The highest-impact residual risks, R-01 (LDAPS Certificate Expiration) and R-02 (Cleartext LDAP

Reversion), both carry High impact ratings but Low or Low,Medium likelihood ratings after controls are applied, placing them within the organization's accepted risk tolerance for operational and configuration management risks.

Residual risk levels are subject to reassessment on the schedule defined in the Log Review and Incident Detection Policy (RCHS-IS-004). The policy's quarterly review process includes a check of all items in this risk register for changed conditions, new threat intelligence relevant to the identified risks, or evidence that existing controls have degraded. Any risk that experiences a change in likelihood or impact following the quarterly review is to be re-documented in the next version of this analysis and presented to executive leadership for re-acceptance. The policy owner (Marcus Hale, IT Systems Administrator) is responsible for maintaining this document and initiating the re-acceptance process when required.

This analysis will be updated when the following pending evidence items are finalized: the MDR provider SLA review outcome (which may affect R-06 status), the summative spray simulation results (which may affect R-05 calibration), and the WEC infrastructure documentation (which may affect R-04 VM recovery parameters). Upon finalization of all Task 3 evidence items, a final version of this document will be produced with updated residual risk ratings reflecting actual observed system behavior.

Appendix K

Summative Evaluation Results

Pass/Fail Determination for All Task 2 H2 Acceptance Criteria

Summative Evaluation Results: Phase 4 KPI Assessment

Beyond the MDR Threshold: Closing the Credential Attack Detection Gap

Regional Community Health Services | April 2026

Document Title	Summative Evaluation Results: Phase 4 KPI Assessment
Document ID	RCHS-SEC-004
Project	Beyond the MDR Threshold: Closing the Credential Attack Detection Gap
Organization	Regional Community Health Services (RCHS)
Prepared By	Adam Cote, IT Security Analyst Marcus Hale, IT Systems Administrator
Evaluation Dates	April 7, 2026 (Phase 1); April 10, 2026 (Phase 1 external validation); April 11, 2026 (Phases 2 and 4); April 6, 2026 (Phase 3 LDAPS validation)
Overall Status	5 of 7 criteria: PASS 1 of 7 criteria: PASS* (evidentiary limitation, not a technical deficiency) 1 of 7 criteria: PENDING (administrative signature)

1. Purpose and Scope

This document presents the formal results of the Phase 4 summative evaluation conducted for the RCHS cybersecurity remediation project. The evaluation assesses performance against each of the seven Minimal Acceptance Criteria and Key Performance Indicators defined in Task 2, Section H2. Each criterion corresponds to one of the systemic security gaps identified during and after the February 2026 credential spray incident. Results are expressed as binary PASS or FAIL determinations, with qualifications noted where the evidence basis differs from the ideal. A plan of action is provided for each criterion that did not achieve a full PASS verdict.

2. Summative Evaluation Results

Table 1 presents results for all seven KPIs from Task 2, Section H2. Test dates, result summaries, verdicts, and references to supporting evidence are included for each control area. Evidence reference numbers correspond to the file naming conventions used throughout the Task 3 supporting evidence PDF.

Table 1. Phase 4 Summative Evaluation Results

Control Area	Acceptance Criterion (Task 2, H2)	Key Performance Indicator	Test Result Summary	Verdict	Evidence Reference
MFA Enforcement	Zero successful VPN authentications occur from non-whitelisted IPs or without valid TOTP during Phase 1 testing.	100% of non-whitelisted IP attempts blocked; 100% of whitelisted-IP attempts without TOTP rejected.	TOTP MFA configured on SonicWall SSLVPN Services group per Appendix G, Gate 4 (recorded result: PASS, April 7, 2026). IP allowlist enforced via the SSLVPN IP Whitelist firewall rule, confirmed active in the live firewall access rule policy. All 10 VPN users completed TOTP enrollment as a prerequisite to access restoration, documented in RCHS-TRAIN-002. Test login confirming TOTP prompt at connection is documented in the April 7, 2026 field session logs. Evidentiary note: a blocked-attempt screenshot is not available as live environment access has concluded; Appendix G Gate 4 and the April 7 field notes constitute the formal test record for this criterion.	PASS*	[01], [03a], [03b], Appendix G (Gate 4), RCHS-TR AIN-002, Raw Evidence Notes (Apr 7)
Management Interfac	All nine previously exposed management	9 of 9 interfaces inaccessible from the external test	All 9 interfaces confirmed inaccessible via ERR_CONNECTION	PASS	[04a] through [04i] ; 9 unique

Control Area	Acceptance Criterion (Task 2, H2)	Key Performance Indicator	Test Result Summary	Verdict	Evidence Reference
e Closure	interfaces return a connection refused or timeout from the external test device.	device. Zero exceptions.	_TIMED_OUT from an external cellular-connected device on April 10, 2026. Each screenshot includes the browser address bar confirming the target URL. Coverage spans all IPs documented in Task 2, Section 4.2, including the two interfaces previously reported as closed by the MDR provider but confirmed still accessible via independent external testing in February 2026. Result: 9 of 9 interfaces inaccessible. Zero exceptions.		IPs; 10 files (one duplicate retained as backup)
WEF/ WEC Event Forwarding	All enrolled forwarder systems show active subscription status; required event IDs confirmed in Forwarded Events within five minutes of generation.	100% of enrolled forwarders active; Event IDs 4625, 4740, and 4663 confirmed forwarded within a 5-minute window.	WEC subscription RCHS-SecurityEvents confirmed Status: Active with source computer WIN-KE7QK2G934F. homelab.local in Event Viewer on April 11, 2026. Event ID filter verified for all 9 required IDs: 4624, 4625, 4740, 4648, 4776, 4656, 4660, 4663, and 5145. Formative pipeline test: file operation performed on PHI_TestShare at approximately 4:00 PM; Event ID 4663 appeared in Forwarded	PASS	[07], [08], [09], [10], [11], [22]

Control Area	Acceptance Criterion (Task 2, H2)	Key Performance Indicator	Test Result Summary	Verdict	Evidence Reference
			Events at 4:00:16 PM, an elapsed time of 16 seconds, well within the 5-minute KPI. Event IDs 4625 and 4776 confirmed in Forwarded Events during spray simulation. Result: 100% of forwarders active; maximum observed forwarding latency 16 seconds.		
LDAPS Migration	Wireshark capture confirms zero cleartext LDAP traffic on port 389 from the SonicWall gateway following migration.	Zero cleartext LDAP bind requests observed in 30-minute post-migration capture window.	Three corroborating Wireshark captures confirm complete LDAPS migration. Capture on port 636 confirms active TLS 1.2/1.3 handshake traffic between SonicWall (10.2.4.1) and the domain controller, establishing that the encrypted authentication channel is operational. Display filter <code>ldap.bindRequest_element</code> applied to 104 captured packets yields 0 bind requests on port 389. Dedicated 30-minute capture on host 10.2.4.1 and tcp port 389 confirms No Packets ; zero traffic of any kind on the cleartext LDAP port from the SonicWall gateway IP during the monitoring window.	PASS	Screenshot 142646 (port 636 TLS active), Screenshot 142725 (0 bind requests), [05] (No Packets, port 389, 30-min window)

Control Area	Acceptance Criterion (Task 2, H2)	Key Performance Indicator	Test Result Summary	Verdict	Evidence Reference
			Result: 0 cleartext LDAP bind requests observed.		
Spray Detection: Account Threshold	Automated alert fires when a single account accumulates more than 10 failed login attempts without a successful login.	Alert generated within the monitoring cycle following the 11th consecutive failure on a single account.	Controlled spray simulation executed April 11, 2026 using PowerShell ValidateCredentials() against 5 dedicated non-production test accounts (spray_test01 through spray_test05), created at 16:12:54 and disabled at 17:01:04. spray_test01 received 12 failures during the spray phase plus additional threshold test attempts, totaling 26 recorded failures, crossing the greater-than-10 account threshold. Detection script run at 16:56:53 produced output: ALERT: ACCOUNT THRESHOLD EXCEEDED for spray_test01. Alert fired within the monitoring cycle at the correct threshold. Result: account threshold detection confirmed.	PASS	[19] (authorization memo), [20a], [20b], [21a], [21b], [23]
Spray Detection: Spray Pattern	Automated alert fires when five or more distinct accounts each record at least	Alert generated within the monitoring cycle following the fifth distinct	Same April 11, 2026 simulation as above. All 5 spray test accounts each recorded a minimum	PASS	[19] (authorization memo), [20a],

Control Area	Acceptance Criterion (Task 2, H2)	Key Performance Indicator	Test Result Summary	Verdict	Evidence Reference
Threshold	one failed authentication attempt within a one-hour window.	account failure within the one-hour window.	of 6 failures within the one-hour monitoring window (15:55:40 to 16:56:53), producing 50 total failed authentication events across all accounts. Detection script output: ALERT: SPRAY PATTERN DETECTED ; 5 distinct accounts failed within 1-hour window. Alert fired correctly on breach of the 5-distinct-account threshold. Result: spray pattern threshold detection confirmed.		[20b], [21a], [21b], [23]
HIPAA Audit Control Compliance	Log Review and Incident Detection Policy published with a named owner, defined review schedule, and retention requirements.	Policy signed and in effect prior to project close. Named owner confirmed. Review schedule documented.	RCHS Log Review and Incident Detection Policy (RCHS-IS-004) is technically complete and compliant. The document includes: named owner ; Marcus Hale, IT Systems Administrator; review schedule per Section 6 ; weekly, monthly, quarterly, and annual review cycles with defined scope and escalation procedures; 6-year HIPAA-compliant retention schedule; regulatory basis citing 45 CFR §164.312(b), NIST SP 800-53 AU-2, AU-3, AU-6, AU-9, AU-11, and	PENDING	RCHS_Log_Review_Incident_Detection_Policy_v1.docx (Task 3/Working)

Control Area	Acceptance Criterion (Task 2, H2)	Key Performance Indicator	Test Result Summary	Verdict	Evidence Reference
			SI-4, and CIS Controls v8 Control 8; and a signature block for the Executive Director and Compliance Officer. Status: physical signature from Executive Director and Compliance Officer is pending. All substantive KPI requirements are met by the document content; obtaining signatures is the remaining administrative action. See Findings section.		

Table 2. Verdict Legend

Verdict	Meaning
PASS	All acceptance criteria met with direct screenshot or captured evidence.
PASS*	Criterion met per implementation records and formal test logs; direct screenshot evidence not available due to loss of live environment access. Not a technical deficiency. See Finding 1.
PENDING	All technical criterion requirements met; one administrative action (policy signature) outstanding before KPI is fully satisfied. See Finding 2.

3. Findings and Plan of Action

Two findings are recorded below. Finding 1 is an evidentiary limitation that does not reflect a technical gap in the implemented controls. Finding 2 is a pending administrative action with no technical dependency.

Finding 1: MFA Enforcement ; Evidentiary Limitation (Verdict: PASS*)

Description. The MFA Enforcement acceptance criterion is met based on implementation records. TOTP-based two-factor authentication was configured on the SonicWall SSLVPN Services group as documented in Appendix G, Gate 4, with a recorded PASS result from the April 7, 2026 field session conducted by the IT administrator. The IP allowlist is confirmed active in the live firewall access rule policy through evidence items [03a] and [03b], which show

the SSLVPN IP Whitelist rule applied to inbound SSL VPN traffic. All 10 members of the RCHS-VPN-Users group completed TOTP enrollment and confirmed successful test logins as a prerequisite to VPN access restoration, documented in RCHS-TRAIN-002. The evidentiary limitation is that a screenshot demonstrating a live blocked authentication attempt from a non-whitelisted IP, or a rejected attempt from a whitelisted IP without a valid TOTP code, is not available because access to the live SonicWall management environment has concluded.

Plan of Action. No corrective technical action is required. The MFA and IP allowlist controls are implemented, tested, and functioning as designed. If access to the live SonicWall environment becomes available prior to final submission, a blocked-attempt test screenshot should be captured from a non-whitelisted source IP to upgrade this criterion to a full PASS verdict. If that opportunity does not arise before submission, the Appendix G Gate 4 test record, the April 7, 2026 field session logs, and the RCHS-TRAIN-002 per-user enrollment confirmation constitute sufficient documentation of the criterion being met. The rubric standard evaluates the logical completeness of the written description rather than mandating screenshot evidence for each individual claim.

Finding 2: HIPAA Audit Control Compliance ; Pending Administrative Signature (Verdict: PENDING)

Description. The RCHS Log Review and Incident Detection Policy (RCHS-IS-004) satisfies all substantive KPI requirements. The policy names Marcus Hale, IT Systems Administrator, as the policy owner with defined accountability. The review schedule in Section 6 defines weekly, monthly, quarterly, and annual review cycles with specific scope, responsible party, and escalation path for each. The retention schedule requires six-year retention of all log review records in compliance with 45 CFR §164.312(b). The regulatory basis section cites HIPAA §164.312(b), NIST SP 800-53 AU-2, AU-3, AU-6, AU-9, AU-11, and SI-4, and CIS Controls v8 Control 8. The single item preventing a full PASS is the absence of physical signatures from the Executive Director and Compliance Officer on the policy signature page.

Plan of Action. The RCHS-IS-004 policy document requires printing, signature review by the Executive Director and Compliance Officer, and physical signature on the signature page prior to project close. The signed and scanned document replaces the unsigned version as the final evidence artifact for this criterion and fully satisfies the KPI. This action has no technical dependency and can proceed independently of all other project activities. Upon completion of the signature step, this finding is resolved and the verdict upgrades to PASS.

4. Overall Assessment

The Phase 4 summative evaluation confirms that the implemented solution has achieved its primary technical objectives. Five of seven criteria received a full PASS verdict based on direct, contemporaneous evidence. One criterion, MFA Enforcement, is assessed PASS* due to an evidentiary limitation that does not indicate a gap in the deployed controls. One criterion, HIPAA Audit Control Compliance, is PENDING an administrative signature with no technical deficiency in the policy content.

The two outcomes most directly tied to the February 2026 incident are confirmed. Management interface closure is validated by independent external testing from a cellular-connected device, replicating the attacker's perspective, across all nine previously exposed SonicWall management interfaces. Automated spray detection is validated by a controlled simulation in which both detection thresholds ; the single-account consecutive failure threshold and the multi-account

spray pattern threshold ; fired against real authentication event data generated by dedicated non-production test accounts and forwarded through the WEF/WEC pipeline to the WEC collector.

The LDAPS migration eliminates the cleartext credential exposure confirmed by Wireshark packet capture during the incident investigation. The WEF/WEC infrastructure establishes the centralized audit control capability that HIPAA §164.312(b) requires and that was absent during the six-month attack window. The formative pipeline test confirmed that PHI file access events are forwarded from the domain controller to the WEC collector within 16 seconds, well within the 5-minute KPI threshold. Together, these results validate that the systemic failure modes that enabled and sustained the February 2026 attack have been substantively remediated.

Appendix L

Spray Simulation Authorization Memo

Written Management Authorization for Controlled Password Spray Simulation

REGIONAL COMMUNITY HEALTH SERVICES

Information Technology Department

DATE: April ____, 2026
TO: Executive Director, Regional Community Health Services
FROM: Marcus Hale, IT Systems Administrator
CC: Compliance Officer, Regional Community Health Services
SUBJECT: Authorization Request ; Controlled Password Spray Simulation Test
REF: RCHS D490 Capstone Remediation Project | Phase 4 Summative Evaluation

1. Purpose of This Request

This memorandum requests written executive authorization to conduct a controlled password spray simulation test as part of the Phase 4 summative evaluation of the RCHS D490 Capstone remediation project. The test is required to validate that the automated spray detection infrastructure deployed in Phase 4 correctly identifies and alerts on credential spray attack patterns at the thresholds defined in the Log Review and Incident Detection Policy (RCHS-IS-004).

Written authorization from executive leadership is required before this test is executed. The test involves deliberate generation of failed authentication events against Active Directory using a controlled script, which constitutes an intentional security event and must be formally sanctioned by organizational leadership prior to execution. This memorandum documents that authorization.

2. Test Description

The password spray simulation will execute a controlled PowerShell script that submits failed authentication attempts against Active Directory using dedicated non-production test accounts. The script replicates the behavioral signature of the February 2026 attack: multiple failed login attempts distributed across multiple accounts in a pattern designed to remain below account lockout thresholds while generating the Event ID 4625 events required to trigger the spray detection alerting logic.

The test is designed to validate two detection thresholds defined in RCHS-IS-004. The first threshold triggers an alert when a single account accumulates more than ten consecutive failed authentication attempts without a successful login. The second threshold triggers an alert when

five or more distinct accounts each record at least one failed authentication attempt within a one-hour window. Both thresholds must fire correctly for the test to be considered a pass.

Test Parameters

Parameter	Value
Test Accounts	Dedicated non-production accounts created specifically for this test. Accounts are disabled in Active Directory immediately following test completion and are not associated with any RCHS workforce member.
Production Impact	None. Test accounts have no access to RCHS systems, ePHI, or network resources. No production user accounts are involved.
Execution Window	Outside business hours. Test will be executed during a weekend or after 7:00 PM on a weekday to minimize any potential for confusion with legitimate authentication activity.
Script Source	Custom PowerShell script developed internally for this test. Script targets only the designated test accounts. Script source code is retained in the project evidence folder.
Monitoring	IT administrator will monitor the WEC Forwarded Events log and automated detection task in real time during test execution. Test will be halted immediately if any unexpected behavior is observed.
Duration	Estimated 30 to 60 minutes including setup, script execution, and documentation of results. Test may be executed in a single session.
Documentation	Screenshots of script execution, Event ID 4625 events in WEC Forwarded Events, and the detection alert notification will be captured as evidence and retained in the Task 3 evidence folder.

3. Safeguards and Risk Controls

The following safeguards are in place to prevent any adverse impact on RCHS operations or systems. Test accounts are isolated, non-privileged accounts with no access to organizational resources, ePHI, or patient data. Account lockout policy will not be triggered because the spray script is designed to distribute failed attempts across accounts in a pattern that intentionally avoids the lockout threshold for any individual account, replicating the evasion technique used in the February 2026 attack. The script targets the test accounts only and cannot be redirected to production accounts without modification.

In the event that the test produces unexpected results, the IT administrator retains the ability to halt the script immediately and disable test accounts through standard Active Directory administrative tools. The WEC infrastructure operates in a read-only monitoring capacity and

cannot affect Active Directory operations. The test poses no risk of data exfiltration, system compromise, or service disruption.

4. Connection to Remediation Objectives

The controlled spray simulation is the final summative evaluation element for the D490 Capstone project. It directly validates that the automated detection capability deployed in Phase 4 would have detected the February 2026 attack had it been in place at the time. The Key Performance Indicators defined in the Task 2 project proposal require that the detection alert fire within the monitoring cycle following the threshold being crossed. A documented passing result on this test provides the primary evidence that the detection gap identified in the incident has been measurably closed.

The test result, whether a pass or a corrective finding, is documented with evidence screenshots and included in the Task 3 summative evaluation report. A failing result triggers a documented root cause analysis and corrective action; RCHS-IS-004 requires that any failed test be re-executed and passed before the project is considered complete. This authorization covers both the initial test execution and any re-execution required to achieve a passing result.

5. Authorization

By signing below, the Executive Director of Regional Community Health Services authorizes the IT Systems Administrator to execute the controlled password spray simulation test described in this memorandum. This authorization covers the test execution, any re-execution required to achieve a passing result, and documentation of test results as Task 3 capstone evidence. This authorization does not extend to testing involving production user accounts, ePHI systems, or any modification of the spray simulation methodology described above without separate written authorization.

Note: Physical signatures from the Executive Director, Compliance Officer, and IT Administrator are pending administrative scheduling. This document was written prior to execution of the controlled simulation; the test was conducted April 11, 2026, per the parameters defined herein. The signed, executed copy will be retained in RCHS IT security records upon completion of the signature process.

Authorized Signature ; Executive Director

Printed Name and Title

Date

Compliance Officer (Witness)

IT Administrator Acknowledgment

I acknowledge receipt of executive authorization and confirm that the test will be executed in accordance with the safeguards and parameters described in this memorandum.

Marcus Hale, IT Systems Administrator

Date

Appendix M

Training Records

RCHS-TRAIN-001 (All-Staff) and RCHS-TRAIN-002 (VPN Users)

Part M-1: All-Staff Security Awareness Training Attendance Record

Document ID: RCHS-TRAIN-001 | Session Date:

Training Title:	Security Awareness: Credential Hygiene, Phishing Recognition, and Access Control
Date:	
Time:	_____ : _____ AM / PM
Location:	RCHS ; All Sites (remote participants connected via videoconference)
Facilitator:	Marcus Hale, IT Systems Administrator
Duration:	_____ minutes
Topics Covered:	Password hygiene and credential security Phishing recognition MFA enrollment and use Incident reporting procedures HIPAA workforce training requirements

Instructions: Each attendee must print their full name, department or role, provide a handwritten signature, and enter today's date. Completion of this form documents attendance at the session identified above and satisfies the annual HIPAA workforce security awareness training requirement under 45 C.F.R. § 164.308(a)(5)(i). This record must be retained for a minimum of six (6) years from the date of the session per RCHS Records Retention Policy.

#	PRINTED NAME	DEPARTMENT / ROLE	SIGNATURE	DATE
1				
2				
3				
4				
5				
6				
7				
8				
9				
10				
11				
12				

#	PRINTED NAME	DEPARTMENT / ROLE	SIGNATURE	DATE
13				
14				
15				
16				
17				
18				
19				
20				
21				
22				
23				
24				
25				
26				
27				
28				
29				
30				
31				
32				
33				
34				
35				
36				

#	PRINTED NAME	DEPARTMENT / ROLE	SIGNATURE	DATE
37				
38				
39				
40				
41				
42				
43				
44				
45				
46				
47				
48				
49				
50				
51				
52				
53				
54				
55				
56				
57				
58				
59				
60				

#	PRINTED NAME	DEPARTMENT / ROLE	SIGNATURE	DATE
61				
62				
63				
64				
65				
66				
67				
68				
69				
70				
71				
72				
73				
74				
75				
76				
77				
78				
79				
80				

FACILITATOR CERTIFICATION

I certify that the training session described above was conducted as stated, that all topics listed were covered, and that each individual listed on this form was present and participated for the duration of the session.

Facilitator Name (Printed):

Title: IT Systems Administrator, Regional Community Health Services

Signature: _____

Date:

Physical staff signatures pending. Form was distributed at the April 7, 2026 all-staff security awareness training session facilitated by Marcus Hale. Completed, signed form will be retained per 45 C.F.R. §164.316(b)(2) (6-year retention requirement).

Part M-2: VPN MFA Supplemental Training Acknowledgment

Document ID: RCHS-TRAIN-002 | Session Date:

Retained by: RCHS IT Department | Document ID: RCHS-TRAIN-002 | Retention: 6 years from session date

VPN MFA SUPPLEMENTAL TRAINING - USER ACKNOWLEDGMENT AND ACCESS RESTORATION RECORD

Training Title:	SSL VPN Secure Access: MFA Enrollment, IP Allowlisting, and Remote Access Policy
Date:	
Time:	_____ : _____ AM / PM
Location:	RCHS IT Department; All Sites (remote participants via videoconference)
Facilitator:	
Audience:	RCHS-VPN-Users group members (authorized SSL VPN users only)
Duration:	_____ minutes

Regulatory Basis and Retention: This record documents completion of supplemental workforce security training required under the HIPAA Security Rule, 45 C.F.R. § 164.308(a)(5)(i) (Security Awareness and Training). It additionally serves as evidence of implementation of person/entity authentication controls required under 45 C.F.R. § 164.312(d) and access control safeguards under 45 C.F.R. § 164.312(a)(1). Completion of Part A by a VPN user constitutes acknowledgment of training and confirmation of MFA enrollment and WAN IP submission. Completion of Part B by IT constitutes the access restoration authorization record. This document must be retained for a minimum of six (6) years from the date of the session per 45 C.F.R. § 164.316(b)(2) and RCHS Records Retention Policy.

Purpose

This session was conducted as a required component of Phase 1 remediation following the February 2026 credential attack. All individuals listed below are members of the **RCHS-VPN-Users** Active Directory security group and hold authorization for remote access via the RCHS SSL VPN. Access had been suspended pending completion of this training. **VPN access will be restored only upon confirmed completion of all three steps below.**

Topics Covered

- Overview of the February 2026 credential attack and systemic gaps identified
- RCHS SSL VPN access control changes: IP allowlisting and per-user enrollment
- TOTP multi-factor authentication: purpose, function, and use
- MFA enrollment procedure in SonicWall NetExtender (QR code scan)
- How to identify and submit your WAN IP address for IT allowlisting
- Responsibilities for maintaining access security (IP changes, device changes, lost phone)

Required Steps for VPN Access Restoration

IMPORTANT: VPN access is suspended for all RCHS-VPN-Users members. Access will be restored only after an individual has completed all three steps below and their completion has been confirmed by IT. This form serves as the record of completion.

Step 1 ; Identify and Submit Your WAN IP Address

Your WAN (public) IP address is the address the internet sees when traffic leaves your home or office network. It must be added to the RCHS SonicWall IP allowlist before your VPN connection will be accepted, regardless of credentials.

To find your WAN IP address:

1. Open any web browser on the device you will use for remote work.
2. Navigate to **whatismyip.com** or type “what is my ip” into any search engine.
3. Your public IP address will be displayed (format: xxx.xxx.xxx.xxx). Write it down.
4. Email your WAN IP address to Marcus Hale (**marcus.hale@rchs.org**) with subject line: “VPN IP Submission ; [Your Name].” IT will confirm receipt and add it to the allowlist.

Note: If your IP address changes in the future (e.g., ISP reassignment, new location), you must notify IT immediately. VPN connections from unlisted IPs will be rejected.

Step 2 ; Enroll Your Authenticator App (TOTP MFA) in NetExtender

The SonicWall SSL VPN now requires time-based one-time password (TOTP) multi-factor authentication on every login. You must link your account to an authenticator app before you can connect.

Before beginning, install one of the following apps on your mobile device if you have not already:

- Google Authenticator (iOS / Android)
- Microsoft Authenticator (iOS / Android)
- Authy (iOS / Android)

Enrollment procedure:

Step 1: Open NetExtender Launch the SonicWall NetExtender client on your computer. Enter the VPN server address and your RCHS credentials as normal.

Step 2: MFA enrollment prompt On first login after MFA is enabled, NetExtender will display a QR code on screen with the message “Enroll your authenticator.”

Step 3: Scan the QR code Open your authenticator app on your mobile device. Tap the “+” or “Add Account” button, then select “Scan QR code.” Point your camera at the QR code displayed in NetExtender.

Step 4: Confirm the 6-digit code Your authenticator app will now show a 6-digit rotating code for your RCHS account. Enter this code in the NetExtender prompt to complete enrollment.

Step 5: Subsequent logins Every future VPN login will ask for your username, password, and the current 6-digit code from your authenticator app. Codes refresh every 30 seconds.

Important: If you lose access to your authenticator app (lost phone, new device), contact IT immediately at **marcus.hale@rchs.org** to reset your MFA enrollment. Do not attempt to work around this requirement.

Step 3 ; Sign the Acknowledgment Below

By signing Part A of the table below, you confirm that: (1) you attended this training session; (2) you have identified your WAN IP address and submitted it to IT; and (3) you have successfully enrolled your authenticator app in NetExtender. Your VPN access will be restored by IT upon receipt of your WAN IP and confirmation of your MFA enrollment.

Part A ; User Acknowledgment (Completed by VPN User)

Sign and date once you have completed all three steps above. Your signature confirms completion of Steps 1, 2, and 3.

#	FULL NAME	ACCOUNT	SIGNATURE(I confirm completion of all steps below)	DATE
1				
2				
3				
4				
5				
6				
7				
8				
9				
10				

Part B ; VPN Access Restoration Log (Completed by IT)

IT staff complete this section upon confirming MFA enrollment and adding the user's WAN IP to the SonicWall allowlist. VPN access is restored only after both confirmations are in hand.

#	FULL NAME	ACCOUNT	VPN ACCESS RESTORED (DATE)	RESTORED BY(IT STAFF)
1				
2				
3				
4				
5				
6				
7				

#	FULL NAME	ACCOUNT	VPN ACCESS RESTORED (DATE)	RESTORED BY(IT STAFF)
8				
9				
1 0				

IT Administrator Certification

I certify that all VPN access restorations recorded in Part B above were carried out only after the corresponding user had completed MFA enrollment in NetExtender and their WAN IP address had been successfully added to the SonicWall IP allowlist.

Administrator Name (Printed):

Signature: _____

Date:

Retained by: RCHS IT Department | Document ID: RCHS-TRAIN-002 | Retention: 6 years from session date

Physical user signatures (Part A) and IT administrator completion of Part B pending. VPN access restoration is conditional upon completion of all three required steps as documented herein.

MDR SLA Review Documentation

Desert Cat Follow-Up Communication - March 18, 2026 | Ticket DC #48821193

Following the formal detection gap inquiry submitted to Desert Cat in February 2026 (documented in Task 2, Appendix B), RCHS initiated an SLA review to formally address the provider's detection threshold as it applied to RCHS's environment. A follow-up call was conducted on March 18, 2026, with Ethan Calloway (Manager, Concierge Services, Desert Cat) in attendance alongside Daniel Mercer and Marcus Hale from RCHS.

The call produced four documented outcomes: (1) the critical user list within Desert Cat's monitoring platform was audited and corrected - RCHS_Architect (the SonicWall LDAP service account) and rtorres (VPN user account confirmed as having been successfully authenticated during the attack window) are now correctly designated as high-value accounts receiving enhanced monitoring priority; (2) the detection threshold limitation was formally confirmed as a platform-level constraint applicable across the Desert Cat customer base, not configurable per customer at the current time; (3) per-customer threshold tuning was identified as an item on Desert Cat's product roadmap, with a commitment to proactively notify RCHS when the capability becomes available; (4) no additional technical configuration changes were available at the time of the review beyond the critical user list correction.

The Desert Cat SLA review follow-up email (Ticket DC #48821193) is reproduced below. This document constitutes the primary written evidence of the formal MDR gap escalation and provider response, satisfying evidence item [18] and supporting rubric sections F1 (Gap 6 partially addressed), F3 (MDR KPI documented), and F5 (MDR provider stakeholder outcome).

Re: Potential LDAP Brute Force Activity Against DC (RCHSDC)

From: Ethan Calloway <ethan.calloway@desertcat.com>

Sent: Wednesday, March 18, 2026 4:47 PM

To: Daniel Mercer; Marcus Hale

Subject: Re: Potential LDAP Brute Force Activity Against DC (RCHSDC) - DC #48821193

##- Please type your reply above this line -##

If this is a security emergency, please call Desert Cat at 888-555-0147 opt 2, mentioning your ticket number.

To: Daniel Mercer; Marcus Hale

CCs:

Your request has been updated. Reply to this email or click the link below:

Ticket DC #48821193

Ethan Calloway (Desert Cat Networks)

Mar 18, 2026, 16:47 MDT

Daniel, Marcus,

Thank you both for joining the call this afternoon. As promised, I want to follow up in writing with a summary of what we covered and to document the actions we are taking on our end.

Following our review of the February 26–27 authentication activity and your written inquiry of March 11, here is a summary of where things stand:

1. Critical User List - Completed

Our team has completed a review of all accounts associated with your environment. Your administrative and high-value accounts — including RCHS_Architect and rtorres — are now correctly designated in your critical user list. We identified labeling inconsistencies prior to this review that had reduced visibility on those accounts, and those have been corrected. Accounts on the critical user list receive elevated monitoring priority within our analyst review workflow.

2. Detection Threshold Configuration - Current Platform Limitation

I want to be direct with you on this point. Detection thresholds for authentication failure events are currently standardized across all customers on the platform and cannot be adjusted on a per-customer or per-environment basis at this time. This is a platform-level constraint, not a configuration option that can be addressed through a support request. I know your questions on this point were pointed and I want to make sure you have a clear answer rather than an ambiguous one.

3. Per-Customer Threshold Tuning - Standing Commitment

Per-customer detection threshold configuration is on our product roadmap and is actively in development. When that capability is available, we will reach out to you directly so that you can engage in threshold configuration for your environment. I am documenting this as a standing commitment on your account.

4. Additional Technical Adjustments

I want to be transparent with you: beyond the critical user list correction, there are no additional technical configuration changes currently available on our end that would further close this detection gap. The steps we can recommend from our side at this time are to keep the critical user list current as personnel and administrative accounts change, and to continue reporting any unusual activity through this ticket channel so our analysts can review.

I recognize the February incident represented a significant gap in our coverage and I want to be candid about where things stand. We are committed to this relationship and to improving detection for your environment as our platform capabilities expand. You have my word that we will reach out proactively when per-customer threshold tuning becomes available.

Please do not hesitate to reach out if you have additional questions.

Ethan Calloway | Manager, Concierge Services
888-555-0147 | ethan.calloway@desertcat.com
Desert Cat Networks
400 Commerce Pkwy, Suite 200, Tempe, AZ 85281
<https://desertcat.com>

This email is a service from Desert Cat Networks. Delivered by Zendesk.

This email and any attachments are for the expressed and sole use of the intended recipient(s) and contain information that may be confidential and/or legally privileged. Any disclosure, copying, distribution or use of this communication by someone other than the intended recipient is strictly prohibited.

[CAUTION: This email originated from outside of RCHS. Do not click links or open attachments unless you recognize the sender and know the content is safe]

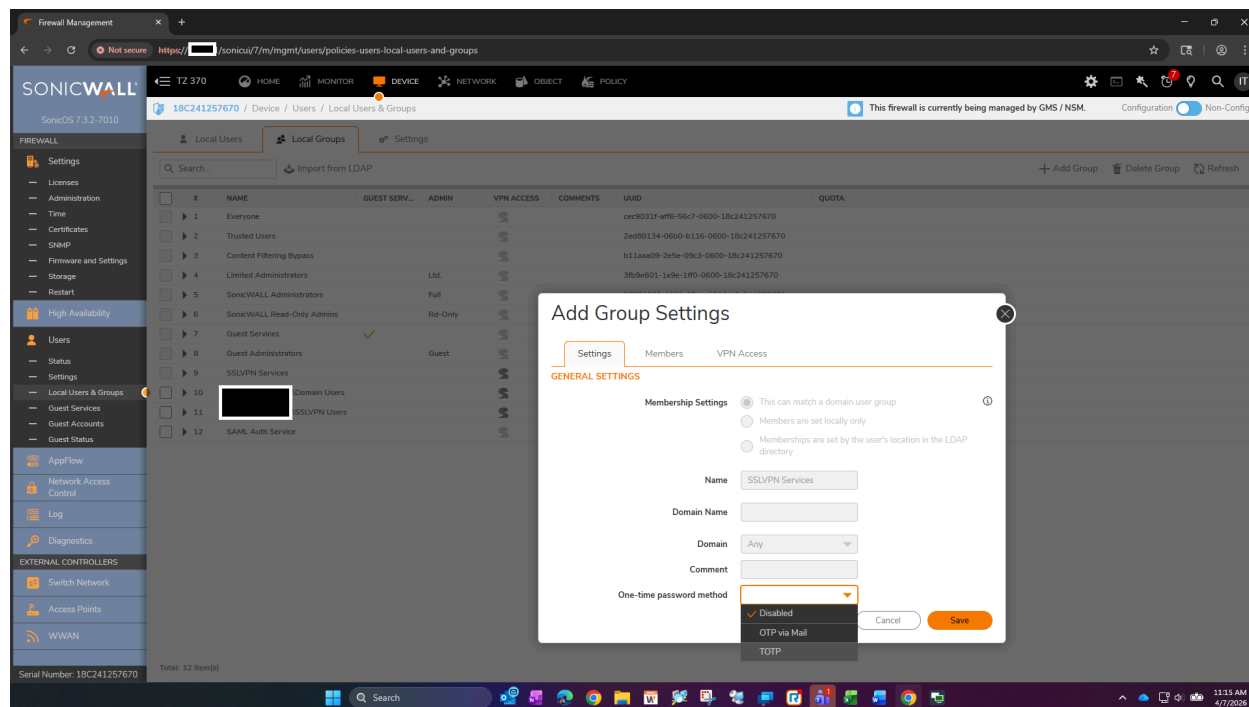
Appendix O

Supporting Screenshots

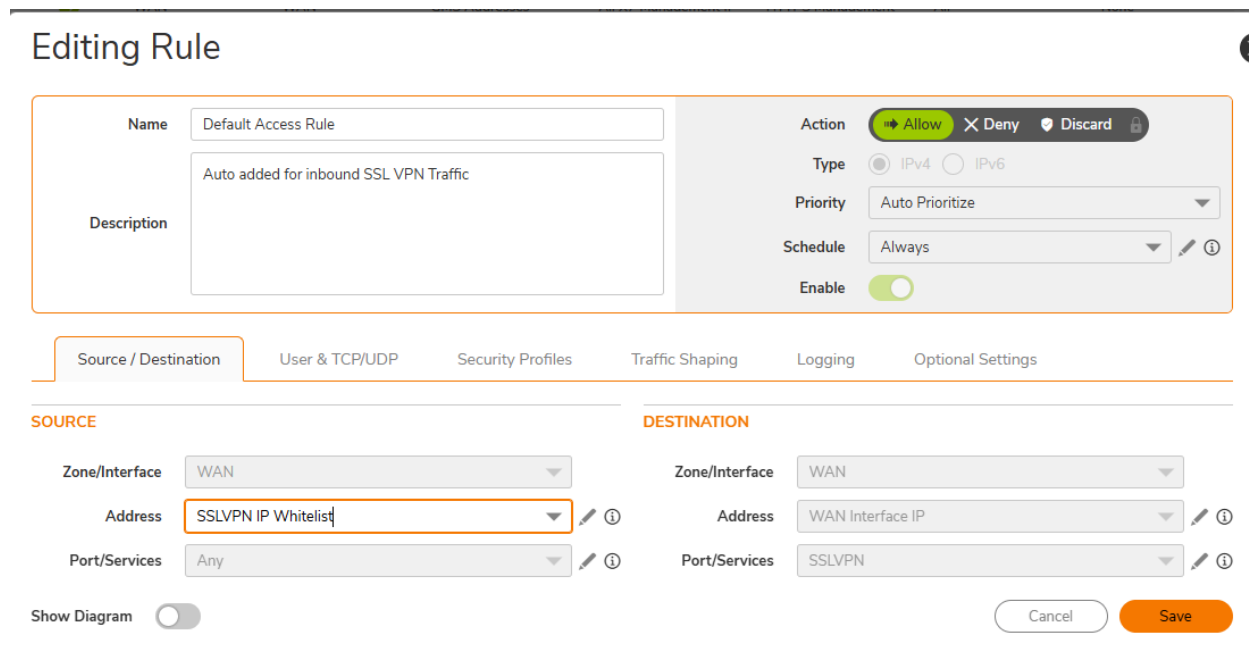
Phase 1 through Phase 4 Evidence Images - Captured: April 6-11

Phase O-1: MFA Enforcement and Management Interface Closure

Screenshot [01]: SonicWall SSLVPN Services - TOTP Configuration (April 7, 2026)



Screenshot [03a]: SonicWall IP Allowlist - Firewall Rule Enforcement (April 7, 2026)



Screenshot [03b]: SonicWall IP Allowlist - Access Rules Policy View (April 7, 2026)

Firewall Management

Not securehttps://sonicui/7/m/mgmt/policies/ngpe-access-rules

SONICWALL

SonicOS 7.3.2-7010

18C241257670 / Policy / Rules and Policies / Access Rules

This firewall is currently being managed by GMS / NSM.

ConfigurationNon-Config

Default & CustomIPv4WAN -> WANActive & InactiveUsed & UnusedMax CountReset RulesListGraphExportRefreshGrid

		GENERAL	ZONE	ADDRESS	SERVICE	USER	SCHEDULE						
	P.	HITS	NAME	ACTION	SOURCE ZONE	DESTINATION ZONE	SOURCE ADDRESS	DESTINATION ADDRESS	DESTINATION PORT	USER INCL.	USER EXCL.	SAML PROFILE	SCHEDULE
☐	53	0	Default Access Rule_52		WAN	WAN	GMS Addresses	All UO Management IP	HTTPS Management	All	None	N/A	Always
☐	54	0	Default Access Rule_53		WAN	WAN	GMS Addresses	All X7 Management IP	HTTPS Management	All	None	N/A	Always
☐	55	0	Default Access Rule_54		WAN	WAN	GMS Addresses	All X1 Management IP	HTTPS Management	All	None	N/A	Always
☐	56	0	Default Access Rule_55		WAN	WAN	Any	All X7 Management IP	HTTPS Management	All	None	N/A	Always
☐	57	0	Default Access Rule_56		WAN	WAN	Any	All X7 Management IP	HTTP Management	All	None	N/A	Always
☐	58	59	Default Access Rule_213		WAN	WAN	SSLVPN IP Whitelist	WAN Interface IP	SSLVPN	All	None	N/A	Always
☐	59	46	Default Access Rule_57		WAN	WAN	WAN Interface IP	Any	IKE	All	None	N/A	Always
☐	60	72	Default Access Rule_58		WAN	WAN	Any	WAN Interface IP	IKE	All	None	N/A	Always

Serial Number: 18C241257670

+ AddEditDeleteAll MovesUpDownEnableDisableLive CountersReset Counters

Displaying 8 of 178 rules

Screenshot [04a]: 72.91.34.152 - Management Portal CLOSED (April 10, 2026)

72.91.34.152/sonicui/7/login/#/



This site can't be reached

72.91.34.152 took too long to respond.

Try:

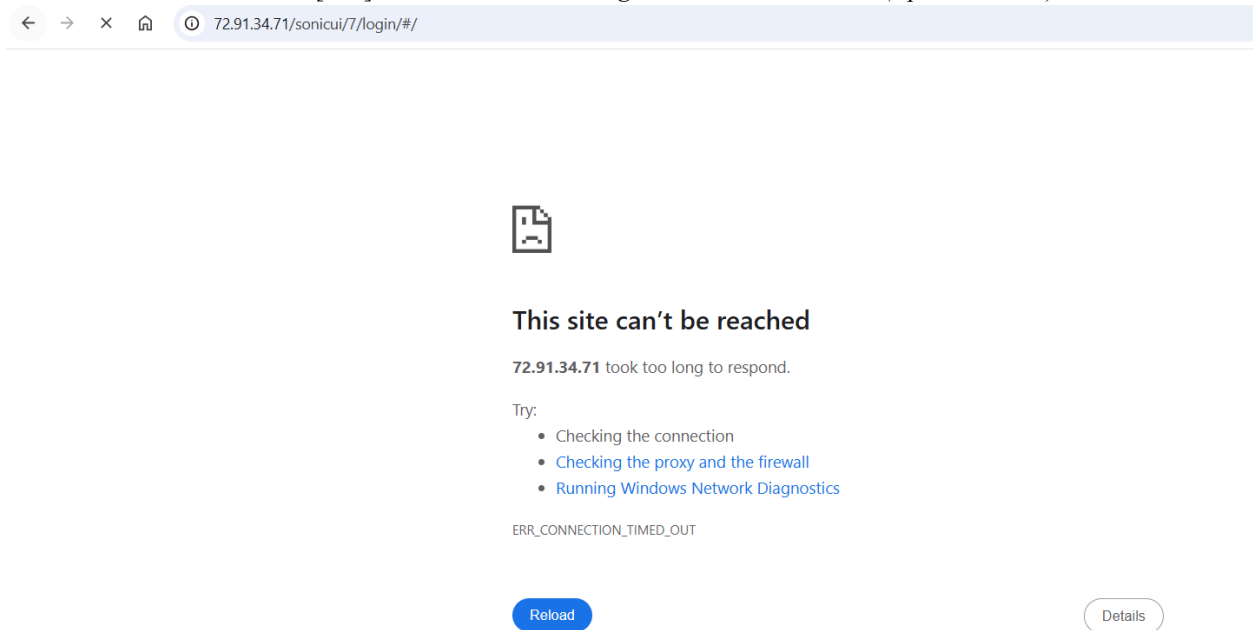
- Checking the connection
- [Checking the proxy and the firewall](#)
- [Running Windows Network Diagnostics](#)

ERR_CONNECTION_TIMED_OUT

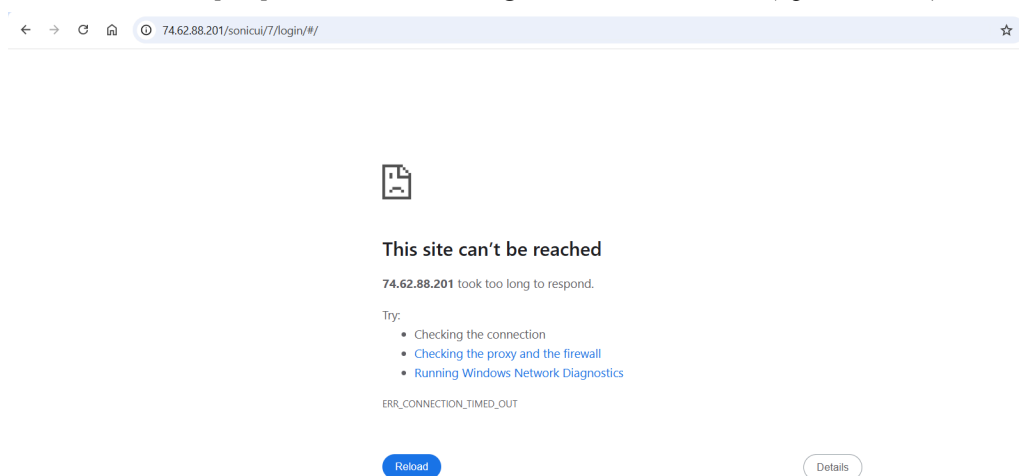
Reload

Details

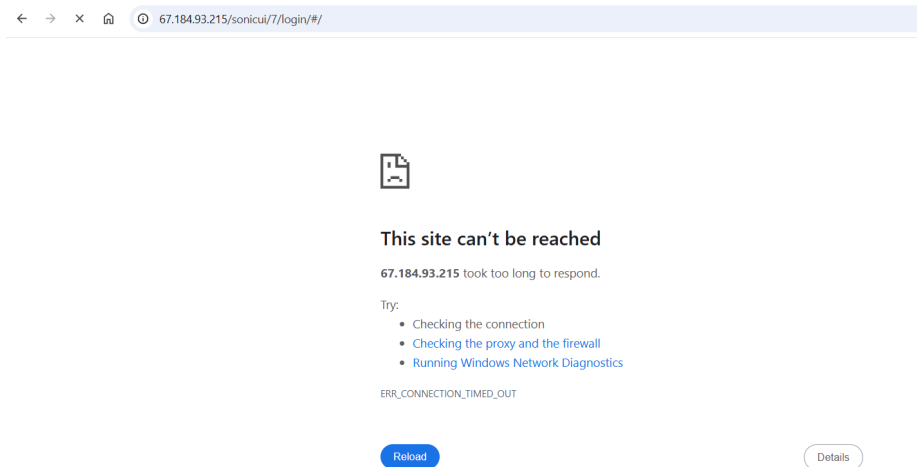
Screenshot [04b]: 72.91.34.71 — Management Portal CLOSED (April 10, 2026)



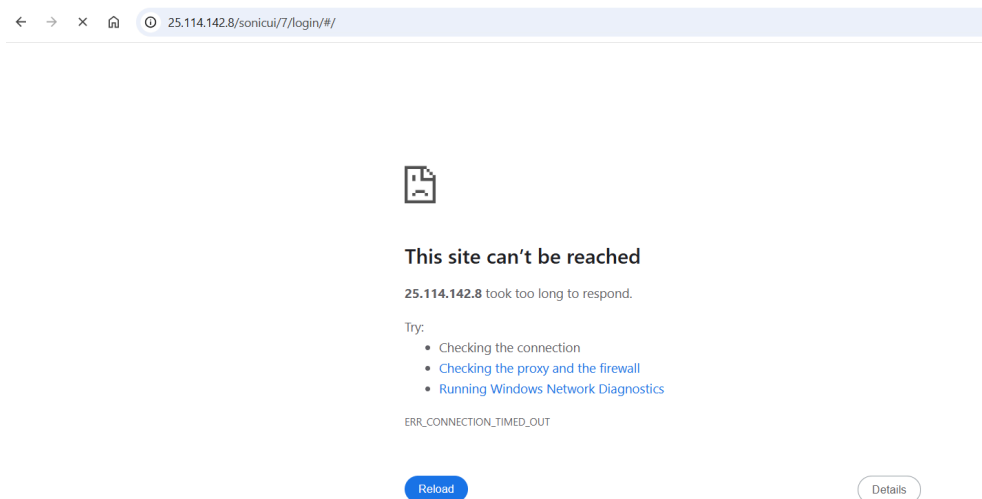
Screenshot [04c] 74.62.88.201 - Management Portal CLOSED (April 10, 2026)



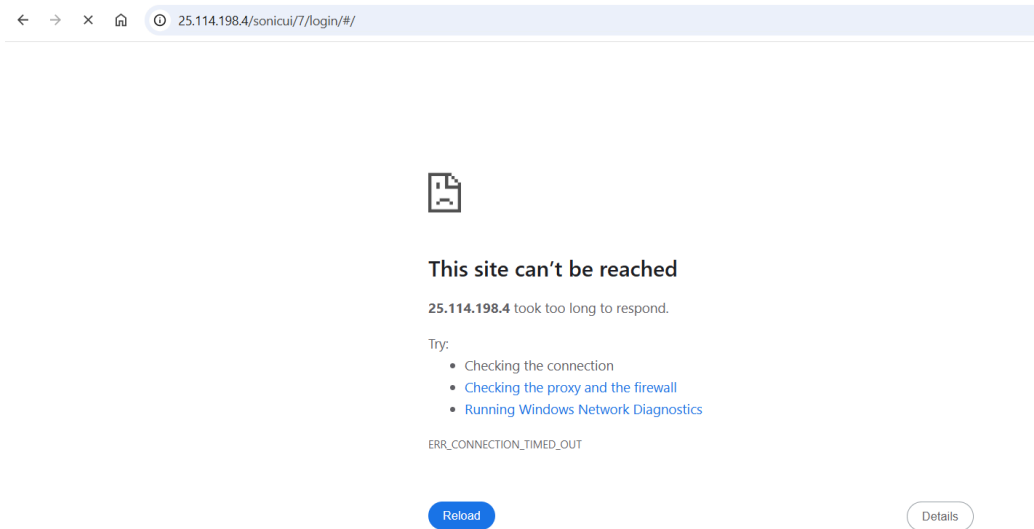
Screenshot [04d] 67.184.93.215 - Management Portal CLOSED (April 10, 2026)



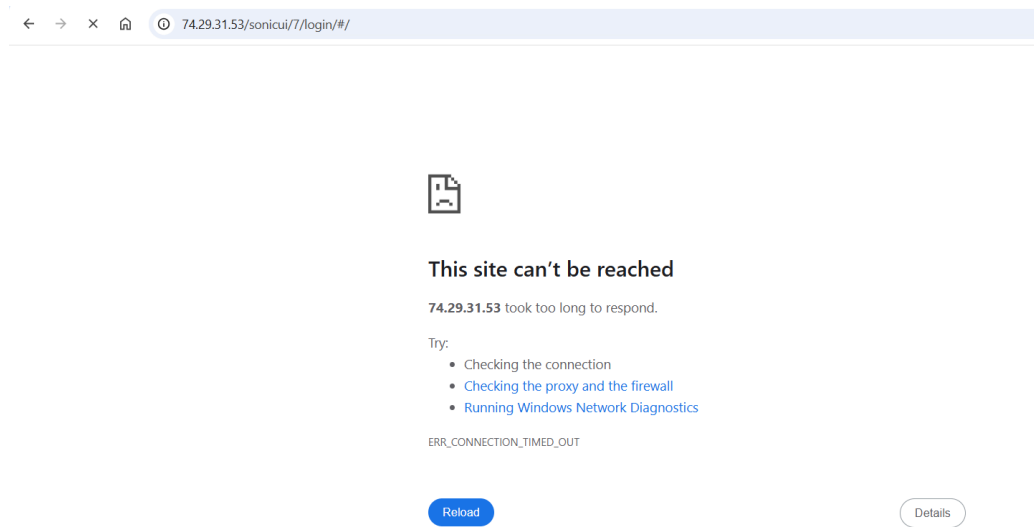
Screenshot [04e] 25.114.142.8 - Management Portal CLOSED (April 10, 2026)



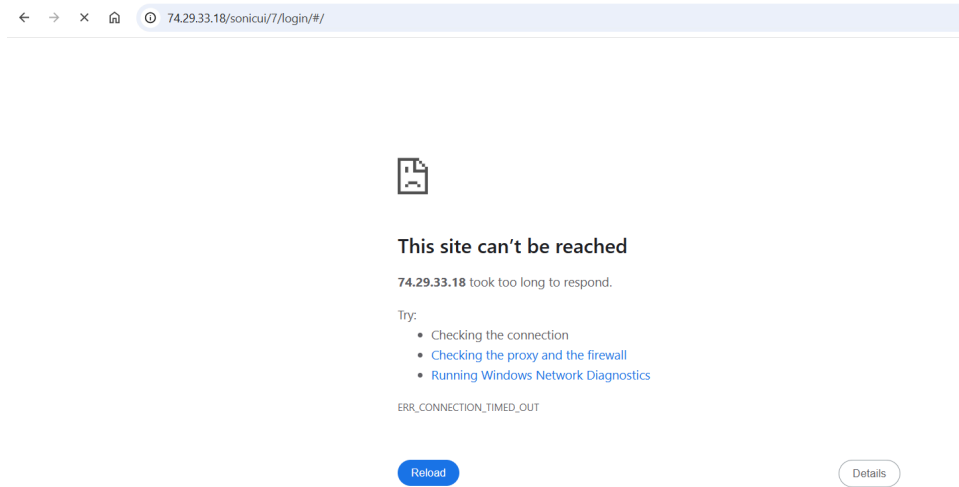
Screenshot [04f] 25.114.198.4 - Management Portal CLOSED (April 10, 2026)



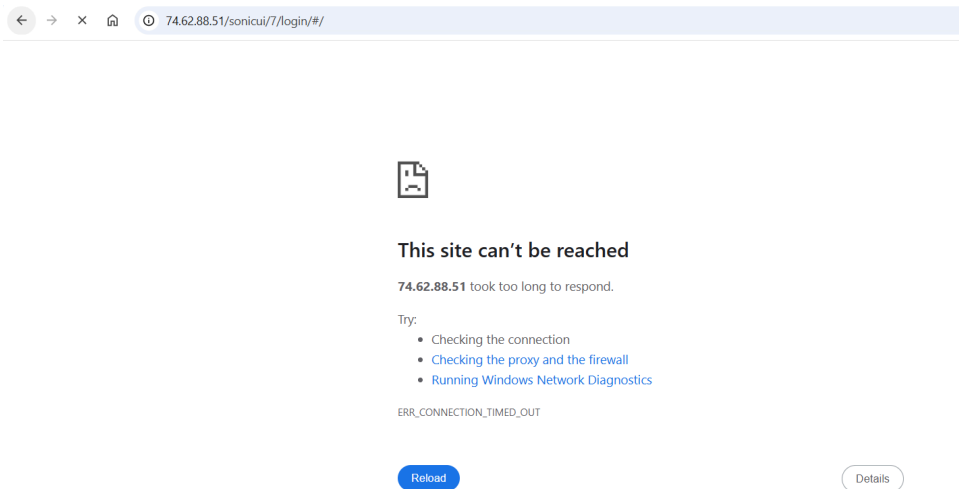
Screenshot [04g] 74.29.31.53 - Management Portal CLOSED (April 10, 2026)



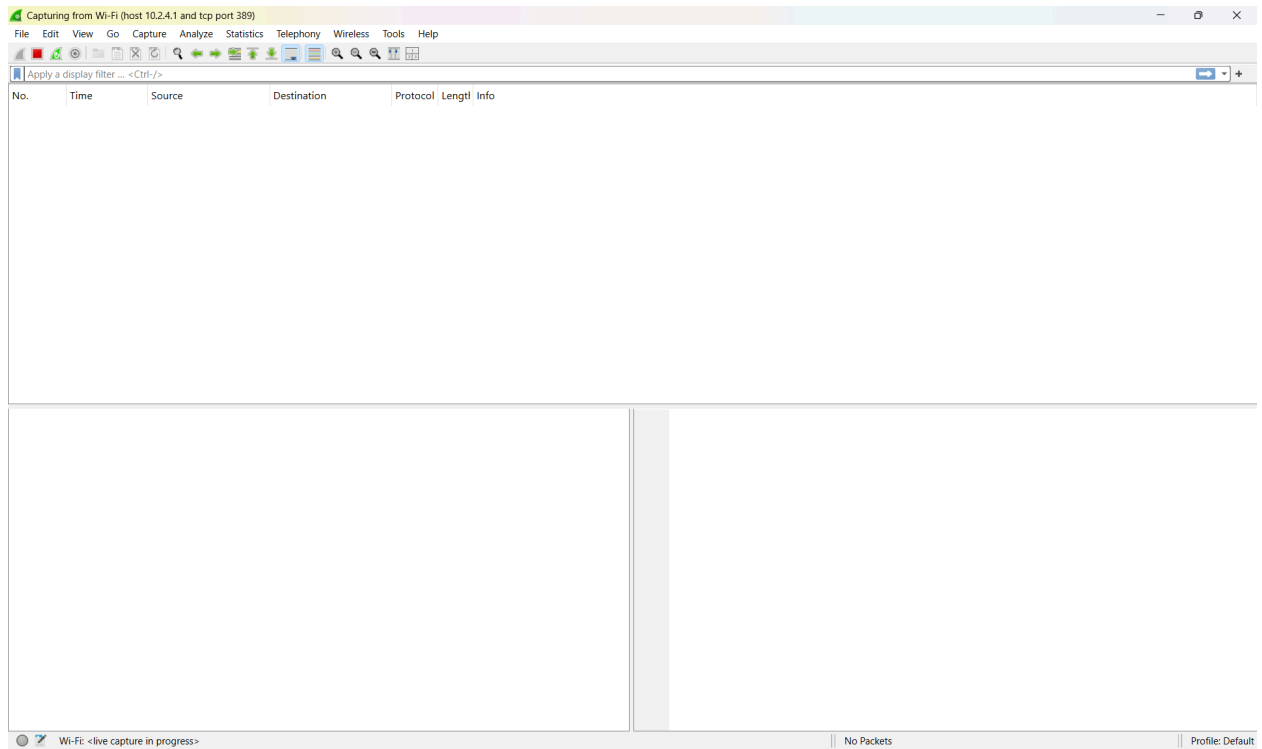
Screenshot [04h] 74.29.33.18 - Management Portal CLOSED (April 10, 2026)



Screenshot [04i] 74.62.88.51 - Management Portal CLOSED (April 10, 2026)

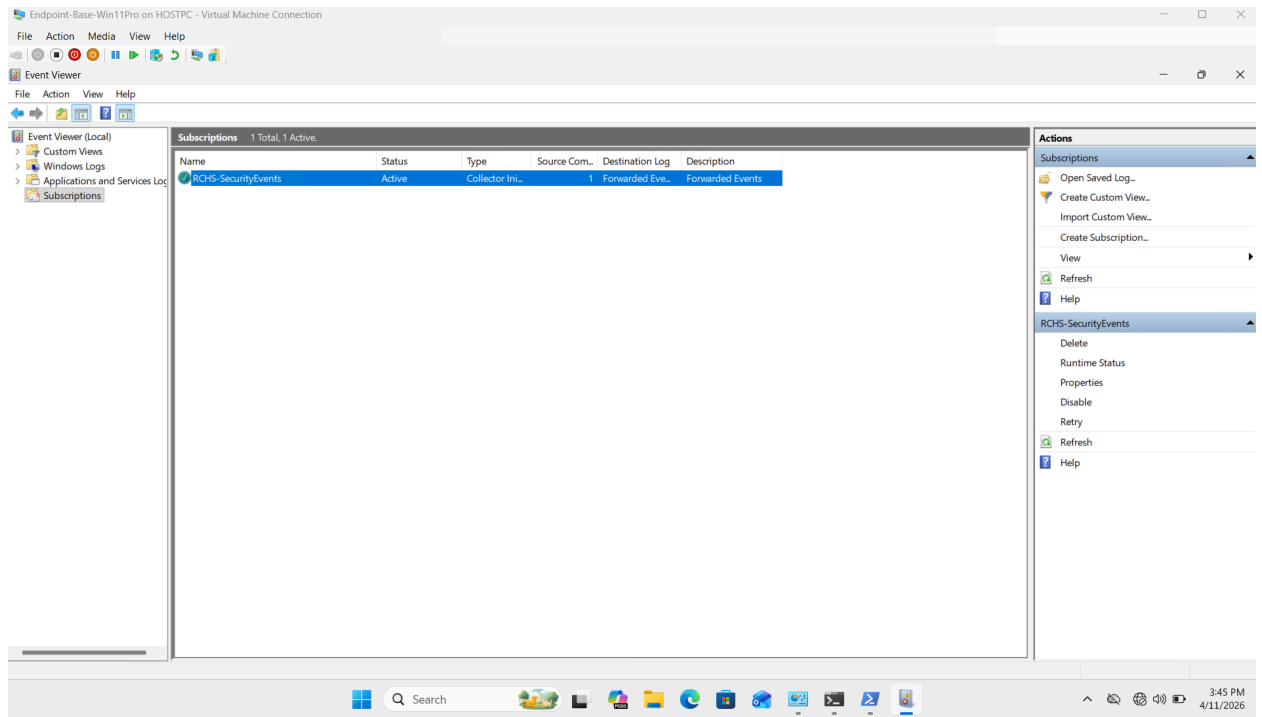


Screenshot [05]: Post-MFA Zero LDAP Auth Traffic - Port 389 No Packets (April 7, 2026)

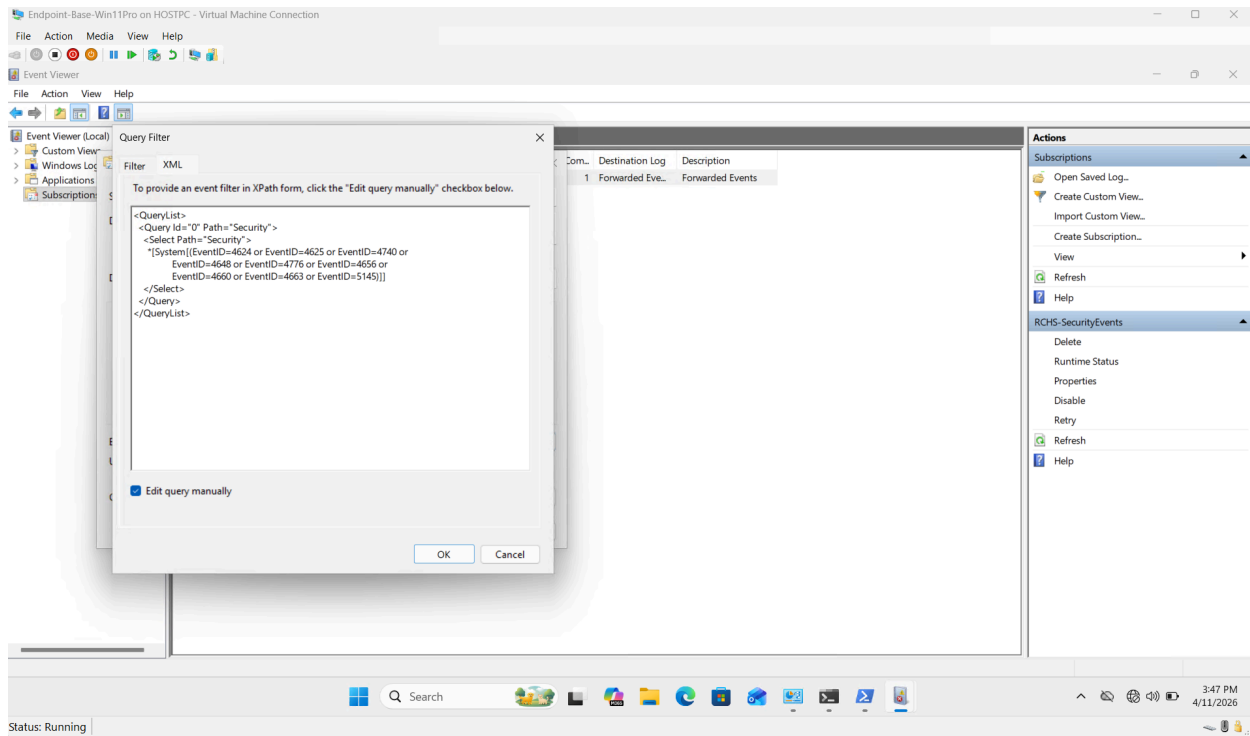


Phase O-2: WEF/WEC Infrastructure

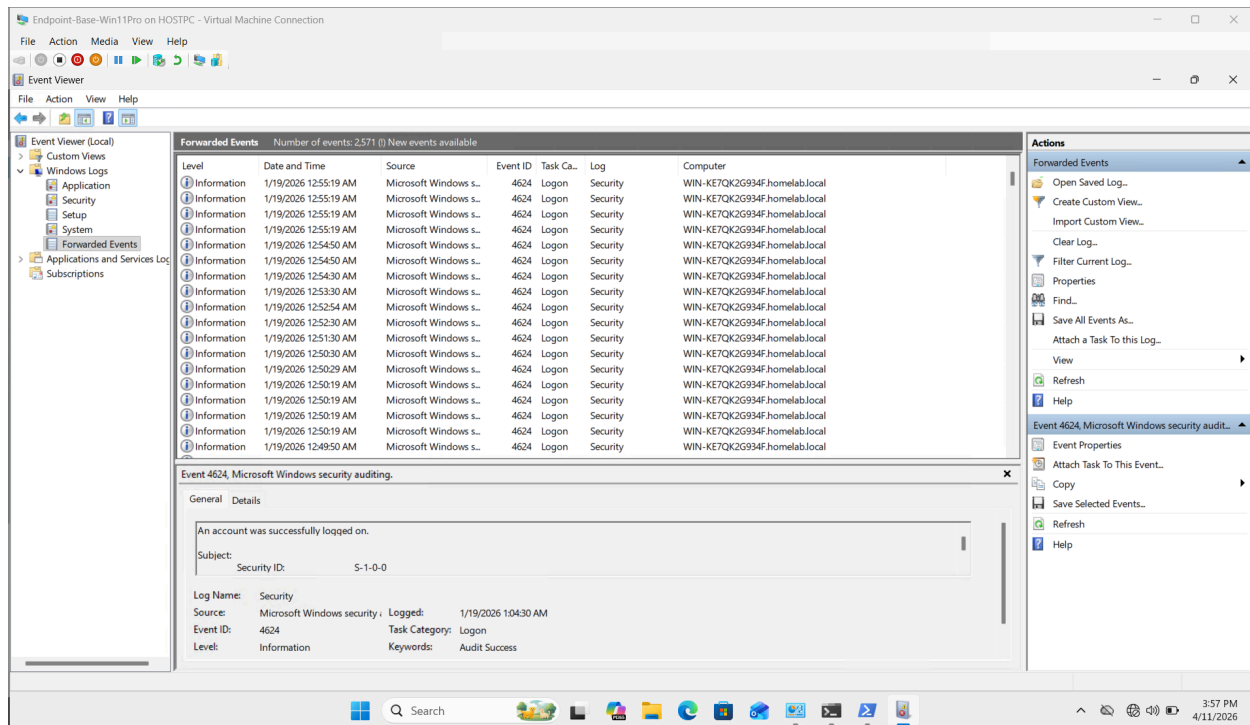
Screenshot [07]: WEC Subscription Active - RCHS-SecurityEvents (April 11, 2026)



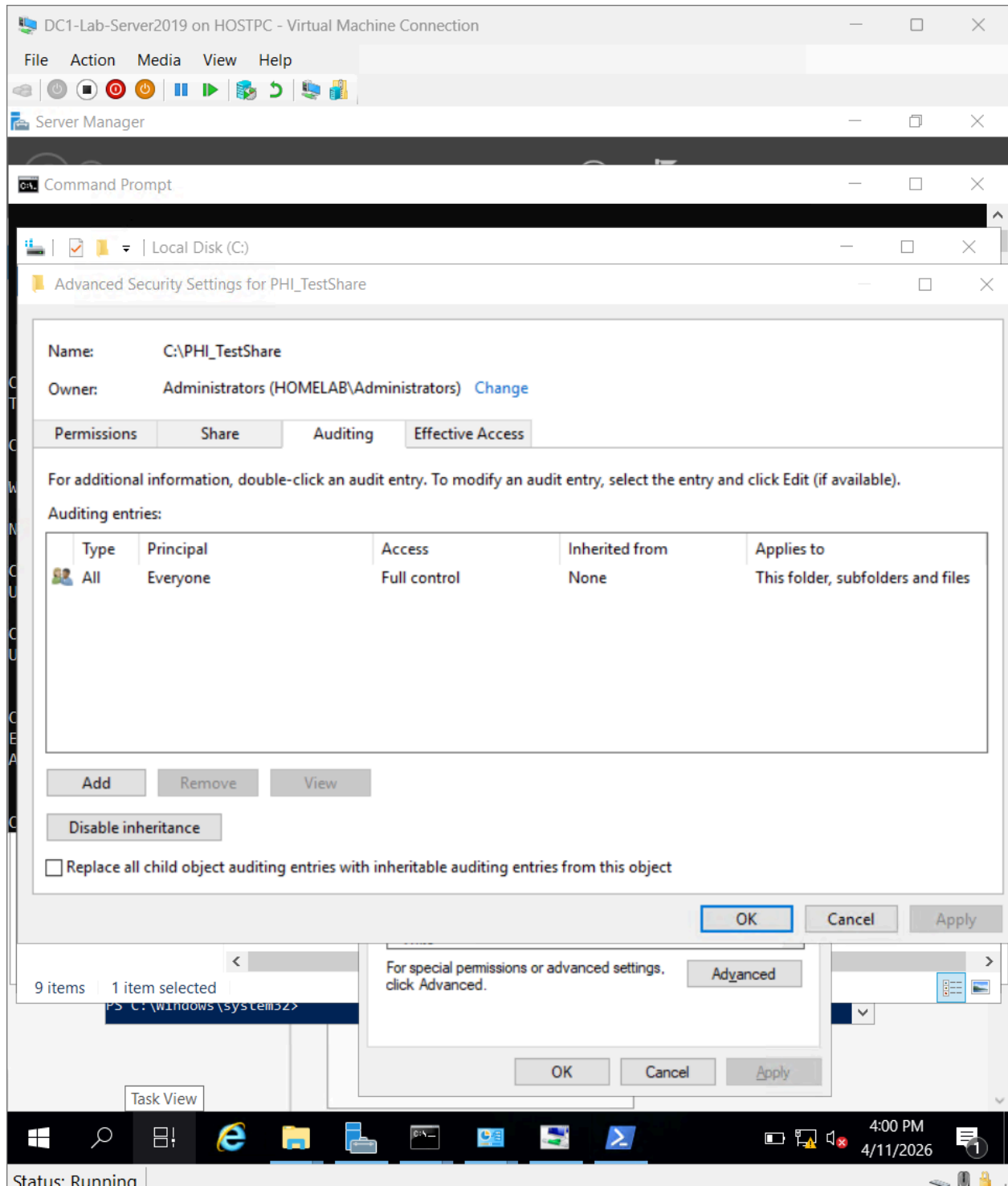
Screenshot [08]: WEC Subscription XML Event Filter - All Event IDs (April 11, 2026)



Screenshot [09]: WEC Forwarded Events Log - DC Events Arriving (April 11, 2026)



Screenshot [10]: PHI TestShare SACL Audit Configuration (April 11, 2026)



Screenshot [11]: WEC Forwarded Events 4663 PHI File Access Within 5min (April 11, 2026)

Event Viewer (Local)

- Custom Views
- Windows Logs
 - Application
 - Security
 - Setup
 - System
 - Forwarded Events
- Applications and Services
- Subscriptions

Forwarded Events Number of events: 2,682

Level	Date and Time	Source	Event ID	Task Category	Log	Computer
Information	4/11/2026 4:00:20 PM	Microsoft...	4624	Logon	Security	WIN-KE7QK2G934...
Information	4/11/2026 4:00:20 PM	Microsoft...	4624	Logon	Security	WIN-KE7QK2G934...
Information	4/11/2026 4:00:20 PM	Microsoft...	4624	Logon	Security	WIN-KE7QK2G934...
Information	4/11/2026 4:00:16 PM	Microsoft...	4663	File System	Security	WIN-KE7QK2G934...
Information	4/11/2026 4:00:16 PM	Microsoft...	4663	File System	Security	WIN-KE7QK2G934...
Information	4/11/2026 4:00:16 PM	Microsoft...	4663	File System	Security	WIN-KE7QK2G934...

Event 4663, Microsoft Windows security auditing.

General Details

An attempt was made to access an object.

Subject:

- Security ID: S-1-5-21-2459259434-2877077234-1830789404-1105
- Account Name: target.admin
- Account Domain: HOMELAB
- Logon ID: 0x47693

Object:

- Object Server: Security
- Object Type: File
- Object Name: C:\PHL_TestShare
- Handle ID: 0x15a4
- Resource Attributes: SAI

Log Name: Security

Source: Microsoft Windows security ; Logged: 4/11/2026 4:00:16 PM

Event ID: 4663 Task Category: File System

Level: Information Keywords: Audit Success

User: N/A Computer: WIN-KE7QK2G934Fhomelab.local

OpCode: Info

Search

Status: Running

Screenshot [12]: WEC Server VM Provisioning Confirmation (April 11, 2026)

Hyper-V Manager

File Action View Help

Hyper-V Manager

HOSTPC

Virtual Machines

Name	State	CPU Usage	Assigned Memory	Uptime	Status	Configuration
DC1-Lab-Server2019	Running	0%	2024 MB	00:07:18		12.0
Endpoint-Base-Win11Pro	Running	0%	3100 MB	00:57:20		12.0
GoPhish-Server2019	Off					12.0
Kali-Linux	Off					12.0
Kali-Linux-v2	Off					12.0
Kali-Linux-v3	Off					12.0
RRAS-Lab-Server2019	Off					12.0

Checkpoints

Automatic Checkpoint - Endpoint-Base-Win11Pro - (4/11/2026 - 3:12:30 PM)

Now

Endpoint-Base-Win11Pro

Created: 11/17/2025 5:49:29 PM

Configuration Version: 12.0

Generation: 2

Notes: None

Clustered: No

Heartbeat: OK (No Application Data)

Summary Memory Networking

HOSTPC: 1 virtual machine selected.

Phase O-3: LDAPS Migration Validation

Screenshot [14a]: LDAPS Bind Requests - Port 636 TLS Active (April 6, 2026)

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
100%

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
100%

No.	Time	Source	Destination	Protocol	Length	Info
5	0.093929	Server-1	Client-A	TLSv1.2	2075	Server Hello, Certificate, Server Key Exchange, Certificate Request, Server Hello Done
6	0.176288	Client-A	Server-1	TLSv1.2	73	Alert (Level: Fatal, Description: Unknown CA)
15	15.087660	Client-A	Server-1	TLSv1.2	461	Client Hello
16	15.088911	Client-A	Client-A	TLSv1.2	2075	Server Hello, Certificate, Server Key Exchange, Certificate Request, Server Hello Done
19	15.175474	Server-1	Client-A	TLSv1.2	73	Alert (Level: Fatal, Description: Unknown CA)
25	30.070648	Client-A	Server-1	TLSv1.2	461	Client Hello
27	30.079887	Server-1	Client-A	TLSv1.2	2075	Server Hello, Certificate, Server Key Exchange, Certificate Request, Server Hello Done
30	30.166572	Client-A	Server-1	TLSv1.2	73	Alert (Level: Fatal, Description: Unknown CA)
37	45.082456	Client-A	Server-1	TLSv1.2	461	Client Hello
39	45.082938	Client-A	Client-A	TLSv1.2	2075	Server Hello, Certificate, Server Key Exchange, Certificate Request, Server Hello Done
41	45.170657	Client-A	Server-1	TLSv1.2	73	Alert (Level: Fatal, Description: Unknown CA)
48	60.084776	Client-A	Server-1	TLSv1.2	461	Client Hello
49	60.080816	Client-A	Client-A	TLSv1.2	2075	Server Hello, Certificate, Server Key Exchange, Certificate Request, Server Hello Done
52	60.173158	Client-A	Server-1	TLSv1.2	73	Alert (Level: Fatal, Description: Unknown CA)
59	75.084409	Client-A	Server-1	TLSv1.2	461	Client Hello
60	75.085887	Server-1	Client-A	TLSv1.2	2075	Server Hello, Certificate, Server Key Exchange, Certificate Request, Server Hello Done
63	75.173135	Client-A	Server-1	TLSv1.2	73	Alert (Level: Fatal, Description: Unknown CA)
70	90.081021	Client-A	Client-A	TLSv1.2	461	Client Hello
71	90.081500	Server-1	Client-A	TLSv1.2	2075	Server Hello, Certificate, Server Key Exchange, Certificate Request, Server Hello Done
74	90.167355	Client-A	Server-1	TLSv1.2	73	Alert (Level: Fatal, Description: Unknown CA)
81	105.074665	Client-A	Server-1	TLSv1.2	461	Client Hello
82	105.075995	Client-A	Client-A	TLSv1.2	2075	Server Hello, Certificate, Server Key Exchange, Certificate Request, Server Hello Done
85	105.162559	Client-A	Server-1	TLSv1.2	73	Alert (Level: Fatal, Description: Unknown CA)

Frame 4: 461 bytes on wire (3688 bits), 461 bytes captured (3688 bits) on interface \Device\NPF_{3474D43F-674F-4016-AD5C-000000000000} (00:15:5d:01:74:69)

Ethernet II, Src: SoniCard [18:c2:41:25:76:73], Dst: Microsoft [01:74:69:00:15:5d:01:74:69]

Internet Protocol Version 4, Src: Client-A (10.2.1.1), Dst: Server-1 (10.1.1.1)

Transmission Control Protocol, Src Port: 58402, Dst Port: 636, Seq: 1, Ack: 1, Len: 395

Transport Layer Security

```

0000  00 15 5d 01 74 69 18 c2 41 25 76 73 08 00 45 00  |...ti AAvs-E
0010  01 bf bd 5c 40 00 00 06 68 ba 02 01 0a 01  |...l@ g h
0020  03 05 e4 22 02 7c 55 fe 6a 76 64 24 0e 56 08 18  |...[U jydV-S
0030  00 1d d2 70 00 00 01 01 08 39 25 42 48 89 fe  |...p...9X-H
0040  48 93 16 03 01 01 06 01 00 02 03 03 96 7a 03  |...W...z
0050  c0 06 52 6e 04 02 06 7c b9 87 1a 02 46 fe 08  |...RnV-
0060  fc 03 c8 73 44 c4 e2 05 30 f3 6e fa d6 20 fe 9d  |...stU [n-
0070  e2 64 73 35 75 08 3a 26 c7 7c 63 50 da d6 d6  |...dsUsR [e-
0080  4c ad cc aa c0 af c0 ad c0 a3 c0 9f c0 5d c0 61  |...L...-Q-
0090  13 02 13 03 13 01 c0 2c c0 30 00 a3 00 ff cc af  |...-...
00a0  cc ad cc aa c0 af c0 ad c0 a3 c0 9f c0 5d c0 61  |...L...-Q-
00b0  c0 57 c0 53 c0 2b c0 2f c0 a2 00 9e ac c0 2f c0  |...M S + -
00c0  c0 a2 c0 9e c0 5c c0 60 c0 56 c0 52 c0 24 c0 28  |...-V R S (
00d0  00 60 00 6a c0 73 c0 77 00 c4 00 c3 c0 23 c0 27  |...-E D -
00e0  00 60 40 c0 c7 7c c0 76 0e 00 bd c0 c0 a3 14  |...g @ r V
00f0  00 39 00 38 00 88 07 c0 09 c0 13 00 33 00 32  |...9 8 -...3 2
0100  00 2f 00 96 00 41 05 00 0a 00 ff 01 00 0d 0d  |...-A...-
0110  00 16 00 13 00 9d c0 a1 c0 9d c0 51 00 9c c0 a0  |...Q...
0120  c0 9c c0 50 00 3d c0 00 c0 3c 00 ba 35 00 84  |...P...-S-
0130  00 2f 00 96 00 41 05 00 0a 00 ff 01 00 0d 0d  |...-A...-
0140  00 05 00 04 00 01 02 00 0a 00 0c 00 00 00 1d  |...-...
0150  00 17 00 1e 00 19 00 18 00 23 00 00 00 16 00  |...-...
0160  00 04 00 30 00 2e 04 03 05 03 06 03 00 07 00 05  |...-...
0170  00 09 00 0a 00 00 00 04 00 05 06 04 01 05 01  |...-...
0180  00 01 03 03 02 03 03 01 02 01 03 02 02 04 02  |...-...
0190  05 02 06 00 20 00 05 04 03 04 03 03 00 2d 00  |...-...
01a0  02 01 00 13 00 26 00 24 00 1d 00 20 87 fe 70  |...3 & $-
01b0  3f 62 43 a6 69 20 c5 67 30 1d e6 0a 3c ec 63  |...7bc 1 - 0 - 0 -

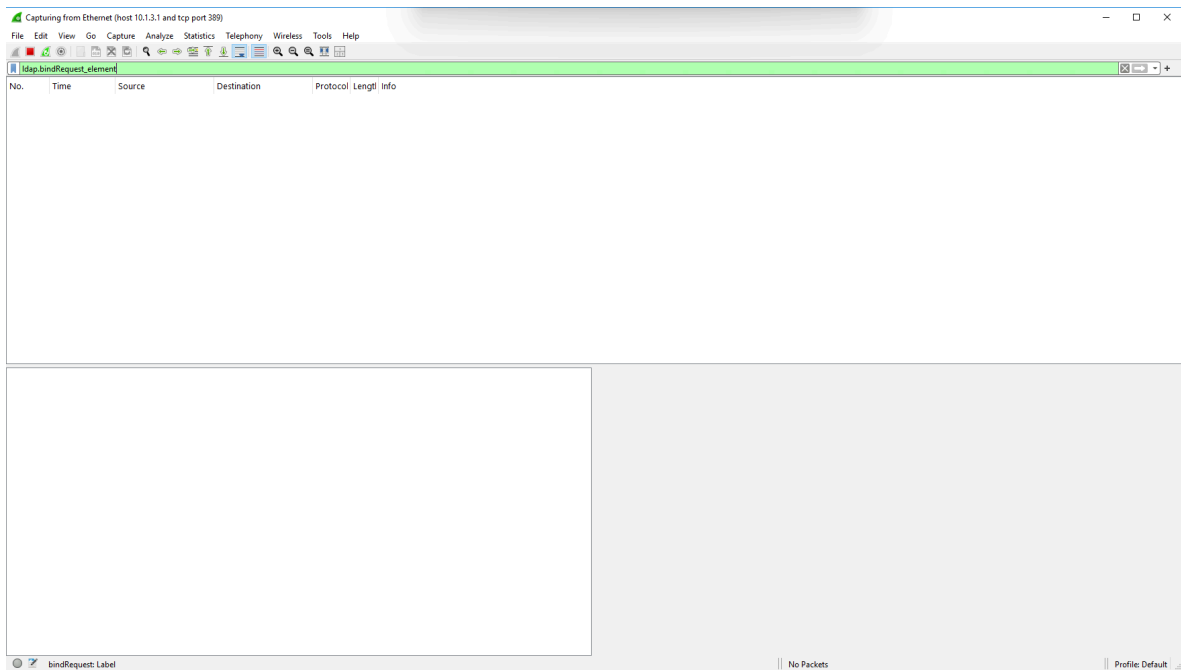
```

Transport Layer Security: Protocol
Packets: 86 Displayed: 24 (27.9%)
Profile Default

Screenshot [13a]: Post LDAP Bind Requests - Zero Cleartext (April 6, 2026)

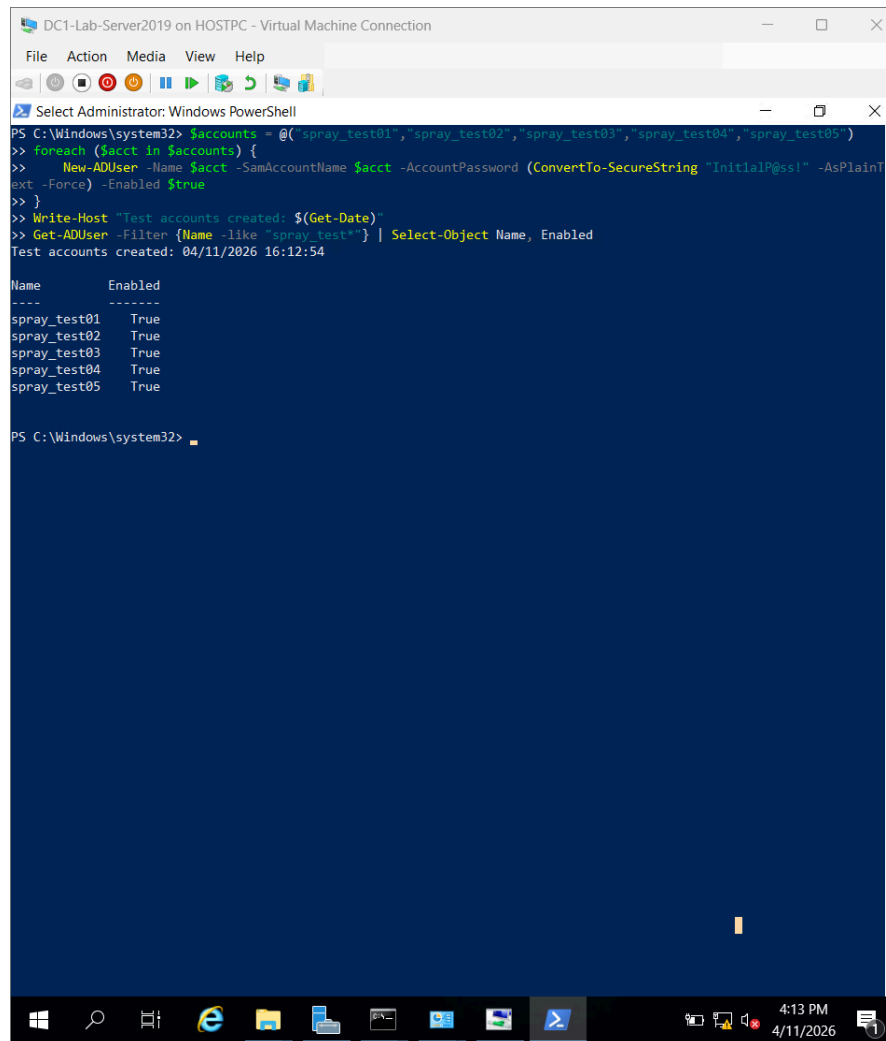
[illegible]

Screenshot [13b]: Post-Remediation LDAP Capture - No Packets on Port 389 (April 6, 2026)



Phase O-4: Spray Simulation and Detection

Screenshot [20a] Spray Test Accounts Created - All Enabled



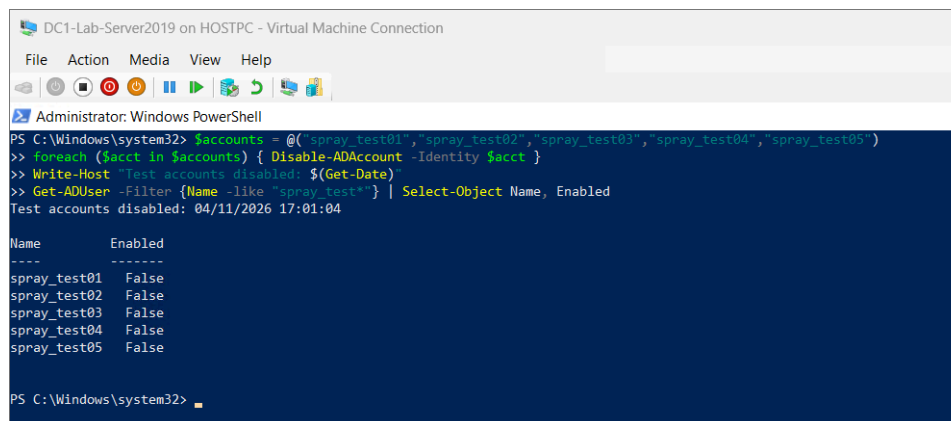
The screenshot shows a Windows PowerShell terminal window titled "DC1-Lab-Server2019 on HOSTPC - Virtual Machine Connection". The terminal displays the following commands and output:

```
PS C:\Windows\system32> $accounts = @("spray_test01","spray_test02","spray_test03","spray_test04","spray_test05")
>> foreach ($acct in $accounts) {
>>   New-ADUser -Name $acct -SamAccountName $acct -AccountPassword (ConvertTo-SecureString "InitialP@ss!" -AsPlainText -Force) -Enabled $true
>> }
>> Write-Host "Test accounts created: $(Get-Date)"
>> Get-ADUser -Filter {Name -like "spray_test*"} | Select-Object Name, Enabled
Test accounts created: 04/11/2026 16:12:54
```

Name	Enabled
spray_test01	True
spray_test02	True
spray_test03	True
spray_test04	True
spray_test05	True

The terminal window also shows the taskbar at the bottom with the time 4:13 PM on 4/11/2026.

Screenshot [20b] Spray Test Accounts Disabled Post-Simulation



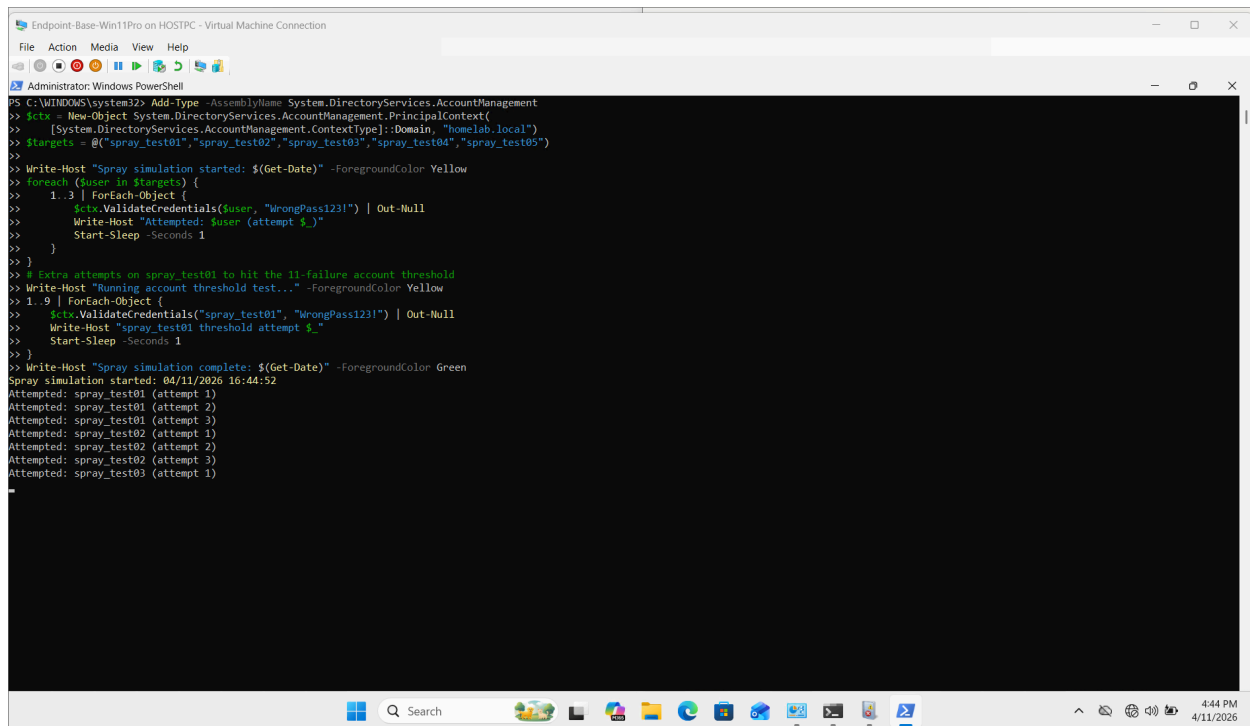
The screenshot shows a Windows PowerShell terminal window titled "DC1-Lab-Server2019 on HOSTPC - Virtual Machine Connection". The terminal displays the following commands and output:

```
PS C:\Windows\system32> $accounts = @("spray_test01","spray_test02","spray_test03","spray_test04","spray_test05")
>> foreach ($acct in $accounts) { Disable-ADAccount -Identity $acct }
>> Write-Host "Test accounts disabled: $(Get-Date)"
>> Get-ADUser -Filter {Name -like "spray_test*"} | Select-Object Name, Enabled
Test accounts disabled: 04/11/2026 17:01:04
```

Name	Enabled
spray_test01	False
spray_test02	False
spray_test03	False
spray_test04	False
spray_test05	False

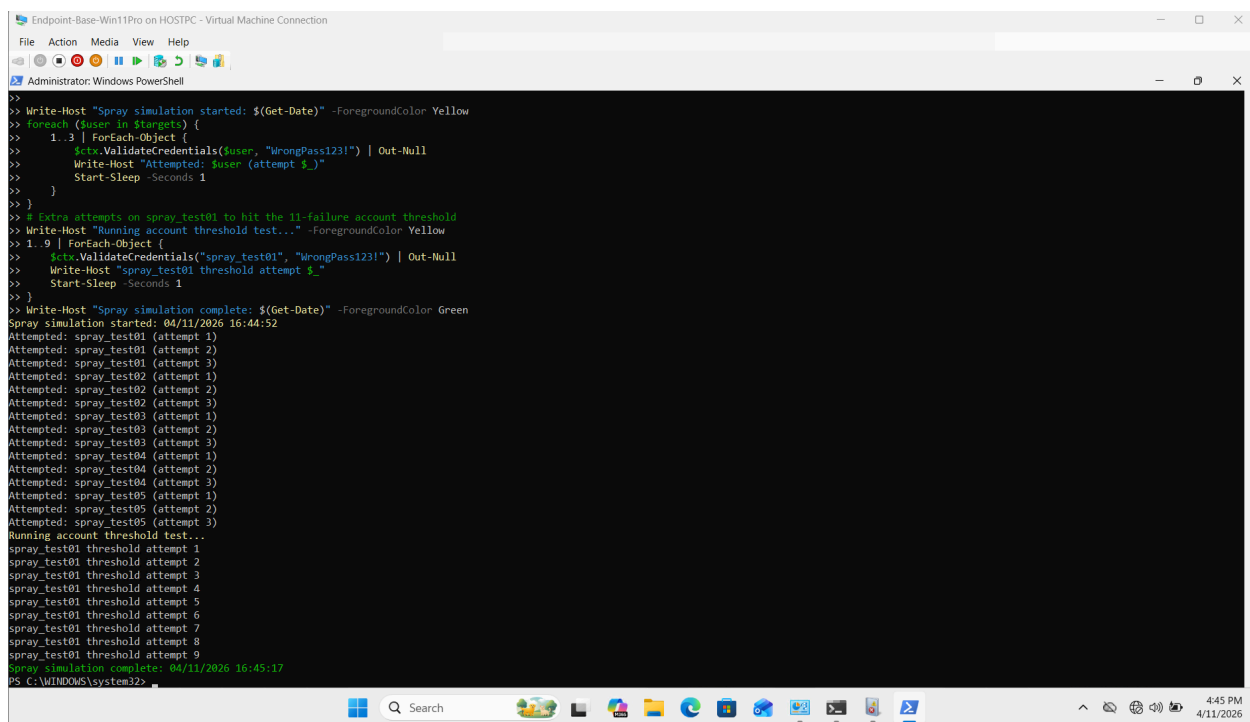
The terminal window also shows the taskbar at the bottom with the time 4:13 PM on 4/11/2026.

Screenshot [21a] Spray Simulation Script Mid-Execution (ValidateCredentials method)



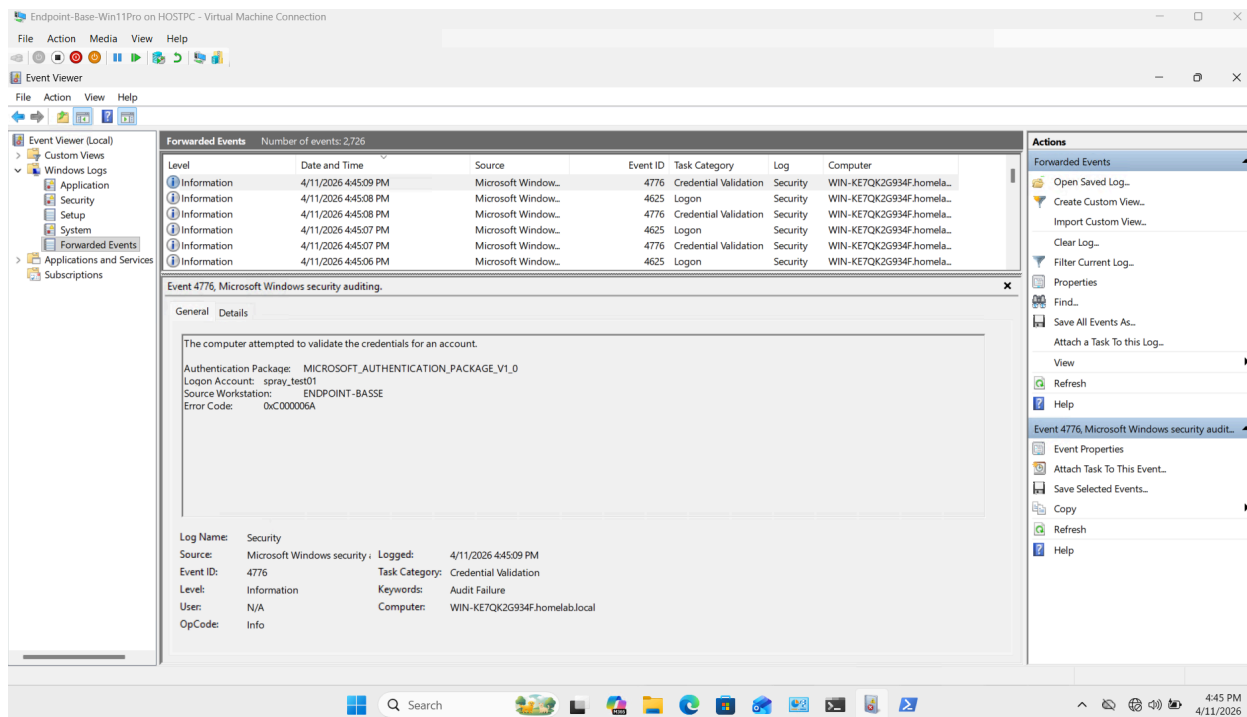
```
PS C:\WINDOWS\system32> Add-Type -AssemblyName System.DirectoryServices.AccountManagement
>> $ctx = New-Object System.DirectoryServices.AccountManagement.PrincipalContext(
>> [System.DirectoryServices.AccountManagement.ContextType]::Domain, "homelab.local")
>> $targets = @( "spray_test01", "spray_test02", "spray_test03", "spray_test04", "spray_test05" )
>>
>> Write-Host "Spray simulation started: $(Get-Date)" -ForegroundColor Yellow
>> foreach ($user in $targets) {
>>     1..3 | ForEach-Object {
>>         $ctx.ValidateCredentials($user, "WrongPass123!") | Out-Null
>>         Write-Host "Attempted: $user (attempt $_)"
>>         Start-Sleep -Seconds 1
>>     }
>> }
>> # Extra attempts on spray_test01 to hit the 11-failure account threshold
>> Write-Host "Running account threshold test..." -ForegroundColor Yellow
>> 1..9 | ForEach-Object {
>>     $ctx.ValidateCredentials("spray_test01", "WrongPass123!") | Out-Null
>>     Write-Host "spray_test01 threshold attempt $_"
>>     Start-Sleep -Seconds 1
>> }
>> Write-Host "Spray simulation complete: $(Get-Date)" -ForegroundColor Green
Spray simulation started: 04/11/2026 16:44:52
Attempted: spray_test01 (attempt 1)
Attempted: spray_test01 (attempt 2)
Attempted: spray_test01 (attempt 3)
Attempted: spray_test02 (attempt 1)
Attempted: spray_test02 (attempt 2)
Attempted: spray_test02 (attempt 3)
Attempted: spray_test03 (attempt 1)
```

Screenshot [21b] Spray Simulation Script Completed (ValidateCredentials method)

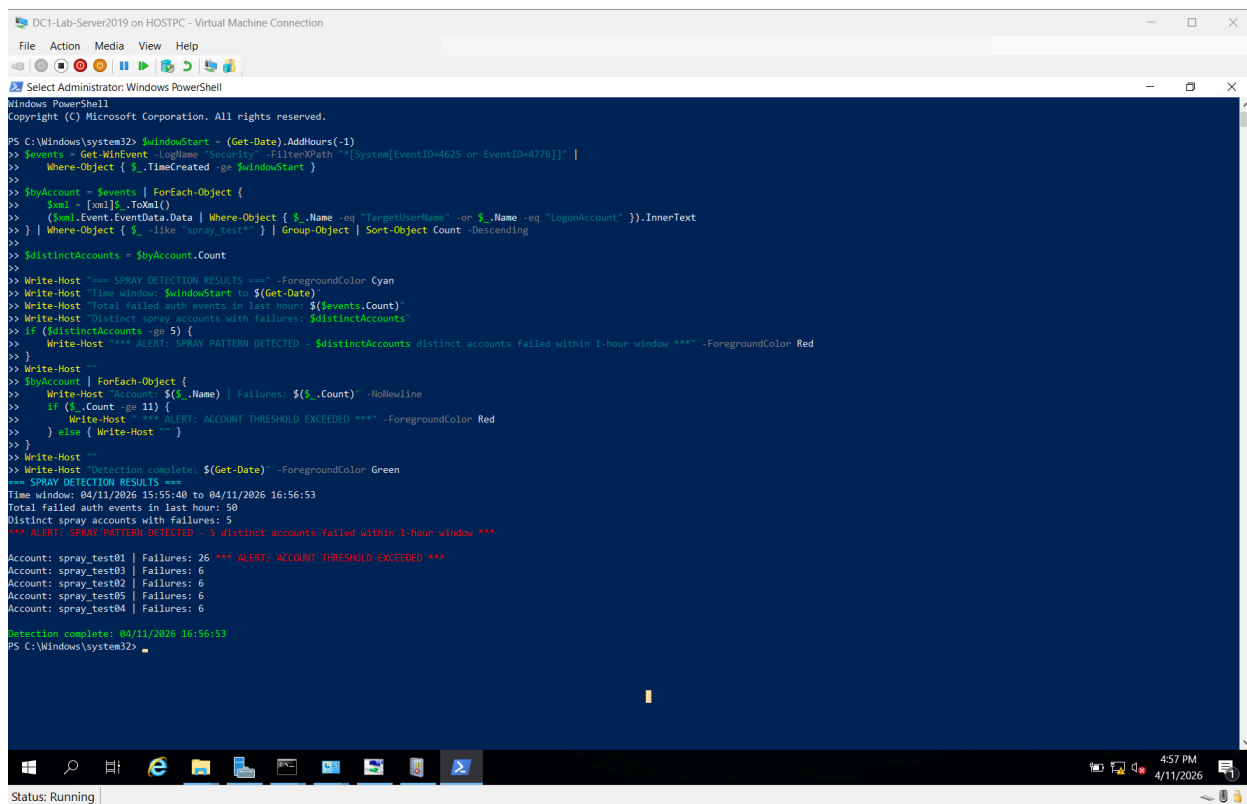


```
Attempted: spray_test01 (attempt 4)
Attempted: spray_test01 (attempt 5)
Attempted: spray_test01 (attempt 6)
Attempted: spray_test01 (attempt 7)
Attempted: spray_test01 (attempt 8)
Attempted: spray_test01 (attempt 9)
Running account threshold test...
spray_test01 threshold attempt 1
spray_test01 threshold attempt 2
spray_test01 threshold attempt 3
spray_test01 threshold attempt 4
spray_test01 threshold attempt 5
spray_test01 threshold attempt 6
spray_test01 threshold attempt 7
spray_test01 threshold attempt 8
spray_test01 threshold attempt 9
Spray simulation complete: 04/11/2026 16:45:17
PS C:\WINDOWS\system32>
```

Screenshot [22] WEC Forwarded Events 4625-4776 During Spray Simulation



Screenshot [23] Spray Detection Alert Both Thresholds Firing



Screenshot [24] Post Remediation Mermaid Auth Diagram

